Draft ETSI EN 304 622 V1.0.0 (2026-08)



HARMONISED EUROPEAN STANDARD

Cyber Security (CYBER);
CRA;
Cybersecurity requirements for Security information and event management (SIEM) systems

Reference
DEN/CYBER-EUS-0010

Keywords
CRA, Cybersecurity, SIEM

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
ETSI Search & Browse Standards application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.
No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.
By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter.
Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights 11
Foreword 11
Modal verbs terminology 12
Introduction 12
1 Scope 13
2 References 13
2.1 Normative references 13
2.2 Informative references 13
3 Definition of terms, symbols and abbreviations 14
3.1 Terms 14
3.2 Symbols 15
3.3 Abbreviations 15
4 Product context 15
4.0 Introduction 15
4.1 Product Functions 16
4.2 Product Architecture 16
4.3 Operational Environment 16
4.3.1 General description 16
4.3.2 Physical/Hardware environment 17
4.3.3 Logical/Software environment 17
4.3.4 Connectivity aspects 17
4.4 Distribution of Security Functions 17
4.4.1 General 17
4.4.2 Security functions provided by the product 17
4.4.3 Security functions provided to the product 18
4.5 Users 18
4.6 Use Cases 18
4.6.1 Overview 18
4.6.2 Guidance 18
4.6.3 UC-1-RESEARCH: Research SIEM 18
4.6.4 UC-2-HOME: Home SIEM 19
4.6.5 UC-3-FLEET: Fleet monitoring 19
4.6.6 UC-4-IOT: IoT monitoring 19
5 Technical requirements for products 20
5.1 Introduction 20
5.1.1 Applicability of the requirements 20
5.1.2 Applicability of Annex K 20
5.1.3 Applicability of Annex R 20
5.2 Appropriate level of cybersecurity 20
5.2.1 Overview 20
5.2.2 REQ-ALC-01 20
5.2.2.1 Requirement 20
5.2.2.2 Applicability 20
5.2.3 REQ-ALC-02 21
5.2.3.1 Requirement 21
5.2.3.2 Applicability 21
5.2.4 Mapping of requirements to use cases 21
5.3 No known exploitable vulnerabilities 21
5.3.1 Overview 21
5.3.2 REQ-KEV-01 21
5.3.2.1 Requirement 21
5.3.2.2 Applicability 21
5.3.2.3 Use-case applicability 21

5.3.3 Mapping of requirements to use cases 22
5.4 Secure by default configuration 22
5.4.1 Overview 22
5.4.2 Requirements 22
5.5 Security updates 22
5.5.1 Overview 22
5.5.2 REQ-SU-01 22
5.5.2.1 Requirement 22
5.5.2.2 Applicability 22
5.5.3 Mapping of requirements to use cases 23
5.6 Authentication and access control 23
5.6.1 Overview 23
5.6.2 REQ-AAC-01 23
5.6.2.1 Requirement 23
5.6.2.2 Applicability 23
5.6.3 Mapping of requirements to use cases 23
5.7 Confidentiality protection 23
5.7.1 Overview 23
5.7.2 REQ-CON-01 23
5.7.2.1 Requirement 23
5.7.2.2 Applicability 23
5.7.3 REQ-CON-02 24
5.7.3.1 Requirement 24
5.7.3.2 Applicability 24
5.7.4 REQ-CON-03 24
5.7.4.1 Requirement 24
5.7.4.2 Applicability 24
5.7.5 Mapping of requirements to use cases 24
5.8 Integrity protection 24
5.8.1 Overview 24
5.8.2 REQ-INT-01 24
5.8.2.1 Requirement 24
5.8.2.2 Applicability 25
5.8.3 REQ-INT-02 25
5.8.3.1 Requirement 25
5.8.3.2 Applicability 25
5.8.4 REQ-INT-03 25
5.8.4.1 Requirement 25
5.8.4.2 Applicability 25
5.8.5 Mapping of requirements to use cases 25
5.9 Data minimisation 25
5.9.1 Overview 25
5.9.2 REQ-DM-01 26
5.9.2.1 Requirement 26
5.9.2.2 Applicability 26
5.9.3 Mapping of requirements to use cases 26
5.10 Availability protection 26
5.10.1 Overview 26
5.10.2 REQ-AP-01 26
5.10.2.1 Requirement 26
5.10.2.2 Applicability 26
5.10.3 REQ-AP-02 26
5.10.3.1 Requirement 26
5.10.3.2 Applicability 26
5.10.4 REQ-AP-03 27
5.10.4.1 Requirement 27
5.10.4.2 Applicability 27
5.10.5 REQ-AP-04 27
5.10.5.1 Requirement 27
5.10.5.2 Applicability 27
5.10.6 Mapping of requirements to use cases 27
5.11 Non-interference 27

5.11.1 Overview 27
5.11.2 REQ-NI-01 28
5.11.2.1 Requirement 28
5.11.2.2 Applicability 28
5.11.3 REQ-NI-02 28
5.11.3.1 Requirement 28
5.11.3.2 Applicability 28
5.11.4 Mapping of requirements to use cases 28
5.12 Attack surface minimisation 28
5.12.1 Overview 28
5.12.2 REQ-ASM-01 28
5.12.2.1 Requirement 28
5.12.2.2 Applicability 28
5.12.3 Mapping of requirements to use cases 29
5.13 Exploit mitigation 29
5.13.1 Overview 29
5.13.2 REQ-EM-01 29
5.13.2.1 Requirement 29
5.13.2.2 Applicability 29
5.13.3 Other requirements 29
5.13.4 Mapping of requirements to use cases 30
5.14 Monitoring 30
5.14.1 Overview 30
5.14.2 REQ-MON-01 30
5.14.2.1 Requirement 30
5.14.2.2 Applicability 30
5.14.3 REQ-MON-02 30
5.14.3.1 Requirement 30
5.14.3.2 Applicability 30
5.14.4 REQ-MON-03 30
5.14.4.1 Requirement 30
5.14.4.2 Applicability 30
5.14.5 Mapping of requirements to use cases 31
5.15 Factory reset and data portability 31
5.15.1 Overview 31
5.15.2 REQ-DRT-01 31
5.15.2.1 Requirement 31
5.15.2.2 Applicability 31
5.15.3 REQ-DRT-02 31
5.15.3.1 Requirement 31
5.15.3.2 Applicability 31
5.15.4 Mapping of requirements to use cases 32
6 Assessment criteria for compliance with technical requirements 32
6.1 Introduction 32
6.1.1 General 32
6.1.2 Guidance for identifying interfaces or data processing 33
6.2 Appropriate level of cybersecurity 33
6.2.1 Overview 33
6.2.2 REQ-ALC-01 33
6.2.2.1 Objective 33
6.2.2.2 Preparation 34
6.2.2.3 Activities 34
6.2.2.4 Verdict 34
6.2.2.5 Evidence 34
6.2.2.6 Guidance 35
6.2.3 REQ-ALC-02 35
6.2.3.1 Objective 35
6.2.3.2 Preparation 35
6.2.3.3 Activities 35
6.2.3.4 Verdict 36
6.2.3.5 Evidence 36

6.3 No known exploitable vulnerabilities 36
6.3.1 Overview 36
6.3.2 REQ-KEV-01 36
6.3.2.1 Objective 36
6.3.2.2 Preparation 36
6.3.2.3 Activities 36
6.3.2.4 Verdict 36
6.3.2.5 Evidence 36
6.4 Secure by default configuration 37
6.4.1 Overview 37
6.5 Security updates 37
6.5.1 Overview 37
6.5.2 REQ-SU-01 37
6.5.2.1 Objective 37
6.5.2.2 Preparation 37
6.5.2.3 Activities 37
6.5.2.4 Verdict 37
6.5.2.5 Evidence 37
6.5.2.6 Guidance 37
6.6 Authentication and access control 38
6.6.1 Overview 38
6.6.2 REQ-AAC-01 38
6.6.2.1 Objective 38
6.6.2.2 Preparation 38
6.6.2.3 Activities 38
6.6.2.4 Verdict 38
6.6.2.5 Evidence 38
6.7 Confidentiality protection 38
6.7.1 Overview 38
6.7.2 REQ-CON-01 38
6.7.2.1 Objective 38
6.7.2.2 Preparation 38
6.7.2.3 Activities 39
6.7.2.4 Verdict 39
6.7.2.5 Evidence 39
6.7.3 REQ-CON-02 39
6.7.3.1 Objective 39
6.7.3.2 Preparation 39
6.7.3.3 Activities 39
6.7.3.4 Verdict 39
6.7.3.5 Evidence 39
6.7.3.6 Guidance 39
6.7.4 REQ-CON-03 40
6.7.4.1 Objective 40
6.7.4.2 Preparation 40
6.7.4.3 Activities 40
6.7.4.4 Verdict 40
6.7.4.5 Evidence 40
6.8 Integrity protection 40
6.8.1 Overview 40
6.8.2 REQ-INT-01 40
6.8.2.1 Objective 40
6.8.2.2 Preparation 40
6.8.2.3 Activities 40
6.8.2.4 Verdict 41
6.8.2.5 Evidence 41
6.8.3 REQ-INT-02 41
6.8.3.1 Objective 41
6.8.3.2 Preparation 41
6.8.3.3 Activities 41
6.8.3.4 Verdict 41
6.8.3.5 Evidence 41

6.8.3.6 Guidance 41
6.8.4 REQ-INT-03 42
6.8.4.1 Objective 42
6.8.4.2 Preparation 42
6.8.4.3 Activities 42
6.8.4.4 Verdict 42
6.8.4.5 Evidence 42
6.9 Data minimisation 42
6.9.1 Overview 42
6.9.2 REQ-DM-01 42
6.9.2.1 Objective 42
6.9.2.2 Preparation 42
6.9.2.3 Activities 43
6.9.2.4 Verdict 43
6.9.2.5 Evidence 43
6.9.2.6 Guidance 43
6.10 Availability protection 43
6.10.1 Overview 43
6.10.2 REQ-AP-01 43
6.10.2.1 Objective 43
6.10.2.2 Preparation 43
6.10.2.3 Activities 43
6.10.2.4 Verdict 43
6.10.2.5 Evidence 44
6.10.3 REQ-AP-02 44
6.10.3.1 Objective 44
6.10.3.2 Preparation 44
6.10.3.3 Activities 44
6.10.3.4 Verdict 44
6.10.3.5 Evidence 44
6.10.4 REQ-AP-03 44
6.10.4.1 Objective 44
6.10.4.2 Preparation 44
6.10.4.3 Activities 44
6.10.4.4 Verdict 44
6.10.4.5 Evidence 45
6.10.5 REQ-AP-04 45
6.10.5.1 Objective 45
6.10.5.2 Preparation 45
6.10.5.3 Activities 45
6.10.5.4 Verdict 45
6.10.5.5 Evidence 45
6.11 Non-interference 46
6.11.1 Overview 46
6.11.2 REQ-NI-01 46
6.11.2.1 Objective 46
6.11.2.2 Preparation 46
6.11.2.3 Activities 46
6.11.2.4 Verdict 46
6.11.2.5 Evidence 46
6.12 Attack surface minimisation 46
6.12.1 Overview 46
6.12.2 REQ-ASM-01 46
6.12.2.1 Objective 46
6.12.2.2 Preparation 47
6.12.2.3 Activities 47
6.12.2.4 Verdict 47
6.12.2.5 Evidence 47
6.12.2.6 Guidance 47
6.13 Exploit mitigation 47
6.13.1 Overview 47
6.13.2 REQ-EM-01 47

6.13.2.1 Objective 47
6.13.2.2 Preparation 47
6.13.2.3 Activities 47
6.13.2.4 Verdict 48
6.13.2.5 Evidence 48
6.14 Monitoring 48
6.14.1 Overview 48
6.14.2 REQ-MON-01 48
6.14.2.1 Objective 48
6.14.2.2 Preparation 48
6.14.2.3 Activities 48
6.14.2.4 Verdict 48
6.14.2.5 Evidence 48
6.14.3 REQ-MON-02 48
6.14.3.1 Objective 48
6.14.3.2 Preparation 49
6.14.3.3 Activities 49
6.14.3.4 Verdict 49
6.14.3.5 Evidence 49
6.14.4 REQ-MON-03 49
6.14.4.1 Objective 49
6.14.4.2 Preparation 49
6.14.4.3 Activities 49
6.14.4.4 Verdict 49
6.14.4.5 Evidence 49
6.15 Factory reset and data portability 49
6.15.1 Overview 49
6.15.2 REQ-DRT-01 50
6.15.2.1 Objective 50
6.15.2.2 Preparation 50
6.15.2.3 Activities 50
6.15.2.4 Verdict 50
6.15.2.5 Evidence 50
6.15.2.6 Guidance 50
6.15.3 REQ-DRT-02 50
6.15.3.1 Objective 50
6.15.3.2 Preparation 51
6.15.3.3 Activities 51
6.15.3.4 Verdict 51
6.15.3.5 Evidence 51

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847 52

Annex B (informative): Security analysis 55
B.0 Overview 55
B.1 Assets 55
B.1.1 Data 55
B.1.2 Hardware 55
B.1.3 Product and monitored element functions 55
B.2 Risk factors 56
B.2.1 Overview 56
B.2.2 [RF-NET] Accessibility of the network connected to product assets 56
B.2.3 [RF-FUN] Sensitivity of product function 56
B.2.4 [RF-NUM] Number of monitored elements 56
B.2.5 [RF-ADM] Availability and skill of administration 56
B.3 Assumptions 57
B.3.1 Overview 57
B.3.2 Proper platform 57
B.3.3 Proper administrator 57
B.3.4 Attacker expends resources proportionate to product assets 57
B.4 Threats and security analysis of threats 57

B.4.1 General 57
B.4.2 Security analysis methodology 57
B.4.3 List of threats, risk assessments, and mitigations 57
B.4.3.1 TH-UEVU: Unknown exploitable vulnerabilities 57
B.4.3.2 TH-KEVU: Known exploitable vulnerabilities 59
B.4.3.3 TH-CACC: Circumvention of access control 60
B.4.3.4 TH-DSTP: Unauthorised access to data stored via used product 60
B.4.3.5 TH-UADT: Unauthorised access to data transmitted or stored 61
B.4.3.6 TH-CONF: Access to assets via configuration errors 62
B.4.3.7 TH-AVAI: Denial of service attack on product 63
B.4.3.8 TH-DDOS: Interference with other devices 64
B.5 Mapping of risk factors to use cases 65

Annexes C to J: Void 66

Annex K (normative): Generic cryptographic requirements and assessment 67
K.1 Cryptography 67
K.1.1 Requirement 67
K.1.2 Assessment of product cryptographic configuration 68
K.1.2.0 General 68
K.1.2.1 Assessment of ACM-listed cryptographic mechanisms 68
K.1.2.1.1 Assessment objective 68
K.1.2.1.2 Assessment preparation 68
K.1.2.1.3 Assessment activities 68
K.1.2.1.4 Assessment evidence 68
K.1.2.1.5 Assessment verdict 69
K.1.2.2 Assessment of ACM-extended cryptographic mechanisms 69
K.1.2.2.1 Assessment objective 69
K.1.2.2.2 Assessment preparation 69
K.1.2.2.3 Assessment activities 69
K.1.2.2.4 Assessment evidence 70
K.1.2.2.5 Assessment verdict 70
K.1.2.3 Assessment of interoperability-based cryptographic mechanisms 70
K.1.2.3.1 Assessment objective 70
K.1.2.3.2 Assessment preparation 70
K.1.2.3.3 Assessment activities 70
K.1.2.3.4 Assessment evidence 71
K.1.2.3.5 Assessment verdict 71
K.2 Crypto agility 71
K.2.1 Requirement 71
K.2.2 Assessment of crypto-agility 72
K.2.2.1 Assessment objective 72
K.2.2.2 Assessment preparation 72
K.2.2.3 Assessment activities 72
K.2.2.4 Assessment evidence 73
K.2.2.5 Assessment verdict 73
K.3 ACM-extended cryptographic mechanisms 73
K.3.1 Requirement 73
K.3.2 List of ACM-extended cryptographic mechanisms 73
K.3.3 Assessment 73
K.4 Interoperability-based cryptographic mechanisms 74
K.4.1 Requirement 74
K.4.2 List of interoperability-based cryptographic mechanisms 74
K.4.3 Assessment 74

Annexes L to Q: Void 75

Annex R (normative): Additional provisions for products relying on Remote Data Processing Solutions (RDPS) 76
R.1 Scope and applicability 76
R.2 RDPS as a product-boundary extension 76
R.3 Threat model 77

R.3.1 Assets 77
R.3.2 Threat catalogue 78
R.3.3 Mapping of assets to threats 79
R.4 Security requirements 79
R.4.1 General and guidance for requirement structure 79
R.4.2 Applicability of Annex R requirements 79
R.4.3 Local product side requirements 80
R.4.3.1 Data authenticity of interactions received from the RDPS side 80
R.4.3.2 Integrity of interactions received from the RDPS side 80
R.4.3.3 Confidentiality of data exchanged with the RDPS side 80
R.4.3.4 Availability 81
R.4.4 RDPS side requirements 82
R.4.4.1 Data authenticity of interactions received from the local product side 82
R.4.4.2 Integrity of interactions received from the local product side 82
R.4.4.3 Confidentiality of data exchanged with the local product side 82
R.4.4.4 Availability 83
R.4.5 Mapping of threats to requirements 84
R.5 Conformity assessment 84
R.5.1 Local product side requirements 84
R.5.1.1 Assessment case for REQ-RDPS-L-AUTH-001 84
R.5.1.2 Assessment case for REQ-RDPS-L-AUTH-002 85
R.5.1.3 Assessment case for REQ-RDPS-L-AUTH-003 86
R.5.1.4 Assessment case for REQ-RDPS-L-INTEG-001 87
R.5.1.5 Assessment case for REQ-RDPS-L-INTEG-002 88
R.5.1.6 Assessment case for REQ-RDPS-L-INTEG-003 88
R.5.1.7 Assessment case for REQ-RDPS-L-CONF-001 89
R.5.1.8 Assessment case for REQ-RDPS-L-CONF-002 90
R.5.1.9 Assessment case for REQ-RDPS-L-CONF-003 91
R.5.1.10 Assessment case for REQ-RDPS-L-AVAIL-001 92
R.5.1.11 Assessment case for REQ-RDPS-L-AVAIL-002 93
R.5.1.12 Assessment case for REQ-RDPS-L-AVAIL-003 93
R.5.2 RDPS side requirements 94
R.5.2.1 Assessment case for REQ-RDPS-R-AUTH-001 94
R.5.2.2 Assessment case for REQ-RDPS-R-AUTH-002 95
R.5.2.3 Assessment case for REQ-RDPS-R-AUTH-003 96
R.5.2.4 Assessment case for REQ-RDPS-R-INTEG-001 97
R.5.2.5 Assessment case for REQ-RDPS-R-INTEG-002 98
R.5.2.6 Assessment case for REQ-RDPS-R-INTEG-003 98
R.5.2.7 Assessment case for REQ-RDPS-R-CONF-001 99
R.5.2.8 Assessment case for REQ-RDPS-R-CONF-002 100
R.5.2.9 Assessment case for REQ-RDPS-R-CONF-003 101
R.5.2.10 Assessment case for REQ-RDPS-R-AVAIL-001 102
R.5.2.11 Assessment case for REQ-RDPS-R-AVAIL-002 103
R.5.2.12 Assessment case for REQ-RDPS-R-AVAIL-003 103
R.6 Mapping of CRA Annex I to Annex R requirements 104

Annex S (informative): Change history 106

History 107

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI IPR online database.

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM**® and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document provides the technical cybersecurity requirements for the products in scope, following a risk-based approach in support of the Cyber Resilience Act (CRA) [i.1]. The technical cybersecurity requirements are therefore proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the products.

Clause 4 does not contain technical requirements; it describes the product context that is considered for the application of this standard.

Clause 4 also defines Use Cases (UCs) that represent the main deployment scenarios reflecting the intended purpose and reasonably foreseeable use of the product, which serve as the basis for identifying relevant cybersecurity risks.

Clause 5 specifies technical cybersecurity requirements for the product to mitigate the identified risks, including their applicability conditions.

Clause 6 specifies the assessment criteria and procedures for verifying compliance with the requirements of clause 5.

Annex A maps the technical requirements of the present document to the essential requirements of the CRA [i.1].

Annex B describes the methodology used to assess the security risks of the products in their context.

Annex K supports the definition of the cryptographic requirements and assessment criteria used by the present document.

Annex R provides supplementary requirements and assessment provisions where a product relies on remote data processing solutions (RDPS) for the provision or support of one or more product functions.

1 Scope

The present document specifies technical requirements and corresponding assessment criteria for Security Information and Event Management related to cybersecurity.

The products with digital elements in scope, hereinafter "SIEM" or "SIEM systems":

- are specified within the "technical description" of the "category of product" number 7 by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as: Products with digital elements that collect data from multiple sources, analyse and correlate that data and present it as actionable information for security-related purposes, such as threat and incident detection, forensic analysis or compliance purposes.
- are covered only within the product context described in clause 4.

The present document covers those products for the purpose of demonstrating compliance with the essential cybersecurity requirements of Regulation (EU) 2024/2847 [i.1] Annex I, Part I under the conditions identified in Annex A.

SIEM systems intended for use in the industrial operational technology (OT) domain are excluded from the scope of the present document, see prEN 50770 series [i.5].

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

[1] ENISA European Cybersecurity Certification Group Sub-group on Cryptography: "Agreed Cryptographic Mechanisms", Version 2.0, April 2025.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

[i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

[i.2] Commission Implementing Regulation (EU) 2025/2392 of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.

[i.3] Standardisation request M/606 - C(2025)618: "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (CENELEC) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020and Directive (EU) 2020/1828 (Cyber Resilience Act)".

[i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements – Vocabulary".

[i.5] prEN 50770 series: "Security for operational technologies" (produced by CENELEC).

[i.6] EU Vulnerability Database (EUVD).

[i.7] BSI TR-02102-1 (Version 2026-01, 31 January 2026): "Cryptographic Mechanisms: Recommendations and Key Lengths".

[i.8] BSI TR-02102-2 (Version 2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths - Use of Transport Layer Security (TLS)".

[i.9] BSI TR-02102-3 (Version 2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths - Use of Internet Protocol Security (IPsec) and Internet Key Exchange (IKEv2)".

[i.10] BSI TR-02102-4 (Version 2026-01): "Cryptographic Mechanisms: Recommendations and Key Lengths - Use of Secure Shell (SSH)".

[i.11] ANSSI Référentiel Général de Sécurité, Annex B2, version 2.0: "Gestion des clés cryptographiques - Règles et recommandations concernant la gestion des clés utilisées dans les mécanismes cryptographiques".

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [i.4] and the following apply:

component: software or hardware intended for integration into an electronic information system

cryptographic mechanism: security-related procedure using cryptography

NOTE 1: The term “cryptographic mechanism” is used in this annex as an umbrella term covering the categories used in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [reference], including cryptographic algorithms, primitives, schemes, protocols, protocol profiles, cipher suites, modes of operation, constructions and parameter sets.

NOTE 2: The terms “cryptographic primitive”, “cryptographic construction”, “cryptographic scheme” and “cryptographic protocol” are used consistently with the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [reference].

NOTE 3: A cryptographic mechanism can be specified at different levels of abstraction. For example, AES is a cryptographic primitive, AES-GCM is a mode of operation / authenticated encryption construction, TLS 1.3 is a protocol, a TLS 1.3 restricted cipher-suite profile is a protocol profile, and TLS_AES_128_GCM_SHA256 is a cipher suite.

cryptographic property: property provided or supported by a cryptographic mechanism

NOTE 1: Cryptographic properties include, for example, confidentiality, integrity, authenticity, entity authentication, message authentication, key establishment, key confirmation, replay protection, collision resistance, second-preimage resistance, pre-image resistance, signature unforgeability, non-repudiation, forward secrecy and password-verifier protection. Where relevant, a cryptographic property can be expressed using a formal cryptographic notion, for example IND-CPA, IND-CCA, IND-CCA2, EUF-CMA, SUF-CMA or authenticated key exchange security.

NOTE 2: A cryptographic property is distinct from a product-level technical requirement, although it can support such a requirement. For example, a secure communication requirement can rely on cryptographic properties such as confidentiality, integrity and authentication.

log: record of an operational event

machine user: virtual user used to access the system programming interfaces

monitored element: a physical or virtual device monitored by the product

product user: person having the credentials to log in to the product to operate administrative actions

secure channel: cryptographically protected communication channel

subject: product user, machine user, or a process being authenticated by the identity provider

trace: record of a system status with all relevant data that can be gathered

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ACM	Agreed Cryptographic Mechanisms
API	Application Programming Interface
CPU	Central Processing Unit
CRA	Cyber Resilience Act
CVE	Common Vulnerabilities and Exposures
DB	Database
DNS	Domain Name System
DHCP	Dynamic Host Configuration Protocol
GUI	Graphical User Interface
IoT	Internet of Things
IP	Internet Protocol
OT	Operational Technology
RDPS	Remote Data Processing Solution
SIEM	Security Information and Event Management
TLS	Transport Layer Security
UC	Use Case
VPN	Virtual Private Network

4 Product context

4.0 Introduction

The product context for SIEM systems is detailed in the following clause. Product context is descriptive, and clause 4 does not contain normative requirements.

4.1 Product Functions

SIEM systems collect, correlate, and analyse data from multiple sources to present as actionable information to users for security-related purposes.

The typical data collection process follows Extract, Transform, and Load (ETL), where the transformations are highly specific for the SIEM operation. During initial data collection, the data may be filtered, normalised, or combined with other sources. The following correlation phase may include data combination, where lookup tables are used to enrich the incoming information.

A typical sequence of events in a SIEM might look like:

1) Sources produce events
2) The events are sent to or collected by the SIEM system
3) The SIEM system does some preliminary data processing on data from a single source
4) The SIEM system processes multiple input sources in the context of each other
5) The SIEM system sends automated alerts, updates statistics, creates reports, etc.

The SIEM system may provide visualisation of incoming information and/or support for the threat and vulnerability management process.

4.2 Product Architecture

A SIEM system collects information from many individual sources into a single system for analysis and reporting. It includes the following elements:

- An API endpoint that passively receives information from the devices being monitored
- Device-specific software that actively collects information from the monitored device and makes it available to the collection API endpoint
- Mediator software that analyses, compresses, filters, and/or deletes collected information as it arrives
- Data warehousing component that stores collected information for long-term access based on the design requirements
- Workflow management and event triggering mechanism that generates events or alerts from the collected information

The data collected through the API endpoint may be generated by specialised SIEM client software, or by standard components of other systems, such as system logging software.

SIEM systems can use RDPS for some components or be installed and operated entirely on user-owned and operated infrastructure. Many commercial SIEM systems use RDPS to implement many parts of the system.

4.3 Operational Environment

4.3.1 General description

SIEM systems range from small home lab deployments to complex systems managing thousands of device reporting streams.

4.3.2 Physical/Hardware environment

The devices that generate the data collected by SIEM systems may run on practically any hardware operating in any physical environment. Some examples:

- servers in a secure data centre
- company laptops carried around by employees
- old computers in a home lab
- telecom infrastructure nodes in locked cabinets
- edge routers for a company intranet

4.3.3 Logical/Software environment

SIEM clients run on a variety of platforms and share the hardware. The collecting, processing, and data storage parts of SIEM are usually installed on a general-purpose operating system, likely using database software to store and query collected data.

4.3.4 Connectivity aspects

By definition, the endpoints and collection servers of a SIEM system are connected to each other in some manner so that the endpoint data can be sent to the collection servers. The network used for the connection may be a fully isolated private network, a private network with a filtered connection to a public network, a virtual private network, a public network, or a combination of these.

4.4 Distribution of Security Functions

4.4.1 General

For each cybersecurity requirement, a product may:

1) Provide some or all of the necessary security functions itself
2) Require some or all of the security functions to be provided by the operational environment
3) Provide security functions used by other components to meet their cybersecurity requirements

4.4.2 Security functions provided by the product

SIEM systems provide the high-level security function of supporting cybersecurity event response through the provision and correlation of cybersecurity-relevant data across multiple devices.

Some of the lower-level security functions of SIEM systems include:

- Monitoring and logging
- Exploit mitigation
- Data minimisation and management
  - Removing data from the device
  - Filtering out sensitive data
  - Automatically and securely deleting data
- Integrity and confidentiality protection by storing data remotely

4.4.3 Security functions provided to the product

Some security functions that may be provided by the operational environment include:

- Secure updates
- Authentication and access control
- Confidentiality protection of stored data
- Integrity protection of stored data
- Availability protection

4.5 Users

Users include both integrators and end users (individuals or groups, consumers or organisations), as well as users with privileged rights or professional training such as administrators. System users can be professional users or consumers and may have different levels of cybersecurity knowledge. Both professional and less experienced users may also have disabilities and may use assistive technology to access the product.

4.6 Use Cases

4.6.1 Overview

The purpose of a use case is to create defined sets of technical requirements (Clause 5) that may be used to treat the risks found by the manufacturer's independent cybersecurity risk analysis.

Use cases are defined by their risk factor levels. The risk factor levels are used by the informative Security Analysis in Annex B to select the group of technical requirements associated with that use case.

Specific use cases are identified by their use case IDs, which are constructed in the following manner:

UC-[X]-[WORD]

Where "X" is a number and "WORD" is a short word that serves to remind the reader of one or more examples.

4.6.2 Guidance

It is not necessary to find a use case whose risks are identical to those identified by the product's cybersecurity risk assessment. If a use case has equal or higher risks to the product's, then it can be used. For example, a use case that includes the product being connected to a public network (a high level of this risk factor) can also be used for a product whose intended purpose is to be connected to a private network with a filtered connection to a public network.

New use cases may be added to the present document along with any new risk factors or requirements necessary to fully treat the risks, along with any necessary updates to the security analysis.

4.6.3 UC-1-RESEARCH: Research SIEM

- Goal: Provide minimum functionality for research or training
- Description:
  - Examples: Simple SIEM for a collection of containers used for research or training
  - Function: Monitor simulated elements
  - Network connectivity: Isolated private network
  - Sensitivity of product functions: Low

- Number of monitored assets: Low
- User administration skill: High

4.6.4 UC-2-HOME: Home SIEM

- Goal: Monitor a small number of home devices
- Description:
  - Examples: Homelab SIEM
  - Function: Monitor home devices for anomalies
  - Network connectivity: Filtered private network
  - Sensitivity of product functions: Medium
  - Number of monitored assets: Low
  - User administration skill: High

4.6.5 UC-3-FLEET: Fleet monitoring

- Goal: Monitor a homogeneous fleet of devices in a controlled area
- Description:
  - Examples: Servers in a data centre, phones in a test lab
  - Function: Monitor health and network traffic within a facility
  - Network connectivity: Filtered private network
  - Sensitivity of product functions: High
  - Number of monitored assets: High
  - User administration skill: High

4.6.6 UC-4-IOT: IoT monitoring

- Goal: Monitor a large fleet of IoT devices
- Description:
  - Examples: SIEM for network-connected washing machines
  - Function: Monitor a large fleet of appliances
  - Network connectivity: Public network
  - Sensitivity of product functions: Medium
  - Number of monitored assets: High
  - User administration skill: Medium

5 Technical requirements for products

5.1 Introduction

5.1.1 Applicability of the requirements

The technical requirements of the present document apply under the product context described in clause 4, which shall be in accordance with its intended use. The product shall comply with all applicable technical requirements of the present document at all times when operating in such a product context.

The requirements in this clause are unconditionally applicable, unless specifically indicated with a conditional phrasing, or the functionality is implemented with RDPS.

5.1.2 Applicability of Annex K

Where the product relies on cryptographic mechanisms for the provision or support of one or more product functions, the product shall satisfy the applicable requirements specified in Annex K.

5.1.3 Applicability of Annex R

Where the product relies on a Remote Data Processing Solution (RDPS) for the provision or support of one or more product functions, the product shall satisfy the applicable requirements specified in Annex R.

NOTE: Annex R specifies supplementary requirements for the product-facing RDPS boundary and does not replace the requirements applicable to the product function as such.

5.2 Appropriate level of cybersecurity

5.2.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (1).

In alignment with the Cyber Resilience Act Annex I Part I (1), this clause addresses overarching risks and mitigations regarding the secure design and development of the product that are not specifically treated by other categorical essential requirements (such as confidentiality, access control, or security updates). The requirements herein ensure the final product itself embodies security by design.

5.2.2 REQ-ALC-01

5.2.2.1 Requirement

All cybersecurity-relevant parts of the product shall implement methods to validate untrusted inputs and mitigate the effects thereof.

5.2.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.2.3 REQ-ALC-02

5.2.3.1 Requirement

The product shall record all system time drift corrections as monitoring events.

5.2.3.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.2.4 Mapping of requirements to use cases

Table 5.2.4-1: Appropriate level of cybersecurity mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-ALC-01		x	x	x
REQ-ALC-02			x	x

5.3 No known exploitable vulnerabilities

5.3.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (a).

5.3.2 REQ-KEV-01

5.3.2.1 Requirement

1) **REQ-KEV-01-1** The product shall have no known exploitable vulnerabilities discovered during testing, or
2) **REQ-KEV-01-2** the product shall not have any known exploitable vulnerabilities discovered during testing that were reported within the previous 14 days, or the time period permitted before public disclosure as described in the vulnerability handling procedure for the product, or
3) **REQ-KEV-01-3** the product shall have no known exploitable vulnerabilities discovered during testing that do not have associated publicly-available documentation explaining the risk and how that risk has been mitigated.

5.3.2.2 Applicability

All products and use cases shall fulfil **at least one** of the above sub-requirements, REQ-KEV-01-1, REQ-KEV-01-2, **or** REQ-KEV-01-3.

NOTE: An exploitable vulnerability's transition from "unknown" to "known" may be by its publication to the EU Vulnerability Database [i.6], an industry-specific vulnerability database, or direct notification to the manufacturer via its own vulnerability reporting process.

5.3.2.3 Use-case applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required

- UC-3-FLEET: required
- UC-4-IOT: required

5.3.3 Mapping of requirements to use cases

Table 5.3.3-1: Known exploitable vulnerabilities mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-KEV-01		x	x	x

5.4 Secure by default configuration

5.4.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (b).

5.4.2 Requirements

The following requirements in other clauses address this essential cybersecurity requirement:

- REQ-ASM-01
- REQ-CON-01
- REQ-CON-03
- REQ-INT-01
- REQ-INT-03
- Requirements in Annex K, as applicable

5.5 Security updates

5.5.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (c).

5.5.2 REQ-SU-01

5.5.2.1 Requirement

The product shall support securely updating the product via the operational environment.

5.5.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.5.3 Mapping of requirements to use cases

Table 5.5.3-1: Security updates mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-SU-01		x	x	x

5.6 Authentication and access control

5.6.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (d).

5.6.2 REQ-AAC-01

5.6.2.1 Requirement

The product shall support authentication and access control for access to the product via the operational environment.

5.6.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.6.3 Mapping of requirements to use cases

Table 5.6.3-1: Authentication and access control mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-AAC-01		x	x	x

5.7 Confidentiality protection

5.7.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (e).

5.7.2 REQ-CON-01

5.7.2.1 Requirement

The product shall support confidentiality protection of the ingested data via the operational environment.

5.7.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required

- UC-4-IOT: required

5.7.3 REQ-CON-02

5.7.3.1 Requirement

The product shall distinguish between confidentiality-protected and non-confidentiality-protected channels between the server and monitored elements in a user-visible way.

5.7.3.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.7.4 REQ-CON-03

5.7.4.1 Requirement

The product shall cryptographically protect the confidentiality of stored secrets.

5.7.4.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.7.5 Mapping of requirements to use cases

Table 5.7.5-1: Confidentiality protection mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-CON-01		x	x	x
REQ-CON-02			x	x
REQ-CON-03		x	x	x

5.8 Integrity protection

5.8.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (f).

5.8.2 REQ-INT-01

5.8.2.1 Requirement

The product shall support integrity protection of the ingested data via the operational environment.

5.8.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.8.3 REQ-INT-02

5.8.3.1 Requirement

The product shall distinguish between integrity-protected and non-integrity-protected channels between the server and monitored elements in a user-visible way.

5.8.3.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.8.4 REQ-INT-03

5.8.4.1 Requirement

The product shall support integrity protection of stored secrets via the operational environment.

5.8.4.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.8.5 Mapping of requirements to use cases

Table 5.8.5-1: Integrity protection mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-INT-01		x	x	x
REQ-INT-02			x	x
REQ-INT-03		x	x	x

5.9 Data minimisation

5.9.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (g).

5.9.2 REQ-DM-01

5.9.2.1 Requirement

The product shall minimise the data processing by the product.

5.9.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.9.3 Mapping of requirements to use cases

Table 5.9.3-1: Data minimisation mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-DM-01		x	x	x

5.10 Availability protection

5.10.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (h).

5.10.2 REQ-AP-01

5.10.2.1 Requirement

The product shall support availability protection via the operational environment.

5.10.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.10.3 REQ-AP-02

5.10.3.1 Requirement

The product shall record log events or emit alerts when it detects ingested data being dropped.

5.10.3.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required

- UC-3-FLEET: required
- UC-4-IOT: required

5.10.4 REQ-AP-03

5.10.4.1 Requirement

The product shall mitigate any impact on product availability caused by monitored elements.

5.10.4.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.10.5 REQ-AP-04

5.10.5.1 Requirement

The product shall limit and fairly allocate memory usage triggered by untrusted input to maintain availability of product functions and the functions of the underlying platform and other products sharing system resources.

NOTE: The product should range check untrusted input fields that trigger memory allocations and rate-limit or drop input that would allocate enough memory to impair the functions of any part of the system.

5.10.5.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.10.6 Mapping of requirements to use cases

Table 5.10.6-1: Availability protection mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-AP-01		x	x	x
REQ-AP-02			x	x
REQ-AP-03			x	x
REQ-AP-04			x	x

5.11 Non-interference

5.11.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (i).

5.11.2 REQ-NI-01

5.11.2.1 Requirement

The product shall minimise the data originating from the product itself that is transmitted to a destination that has not been verified as requesting the transmitted data.

5.11.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.11.3 REQ-NI-02

5.11.3.1 Requirement

The product shall minimise the impact on other products or services sharing data storage with the product.

5.11.3.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.11.4 Mapping of requirements to use cases

Table 5.11.4-1: Non-interference mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-NI-01		x	x	x
REQ-NI-02			x	x

5.12 Attack surface minimisation

5.12.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (j).

5.12.2 REQ-ASM-01

5.12.2.1 Requirement

The exposure of product interfaces shall be minimised in its secure-by-default configuration.

5.12.2.2 Applicability

- UC-1-RESEARCH: not required

- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.12.3 Mapping of requirements to use cases

Table 5.12.3-1: Attack surface minimisation mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-ASM-01		x	x	x

5.13 Exploit mitigation

5.13.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (k).

5.13.2 REQ-EM-01

5.13.2.1 Requirement

The product shall detect and report loss or degradation of monitoring data from monitored elements.

5.13.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.13.3 Other requirements

The following requirements also address this essential cybersecurity requirement:

- REQ-ALC-01
- REQ-ALC-02
- REQ-MON-01
- REQ-MON-02
- REQ-MON-03
- REQ-AP-01
- REQ-AP-02
- REQ-AP-03

5.13.4 Mapping of requirements to use cases

Table 5.13.4-1: Exploit mitigation mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-EM-01			x	x

5.14 Monitoring

5.14.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (l).

5.14.2 REQ-MON-01

5.14.2.1 Requirement

The product shall record cybersecurity relevant events.

5.14.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.14.3 REQ-MON-02

5.14.3.1 Requirement

The product shall protect internal log data from unauthorised access.

5.14.3.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.14.4 REQ-MON-03

5.14.4.1 Requirement

The product shall not modify internal log data in contravention of the product's log retention policy, if any.

5.14.4.2 Applicability

This requirement applies to products with a product log retention policy.

- UC-1-RESEARCH: not required

- UC-2-HOME: not required
- UC-3-FLEET: required
- UC-4-IOT: required

5.14.5 Mapping of requirements to use cases

Table 5.14.5-1: Monitoring mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-MON-01		x	x	x
REQ-MON-02		x	x	x
REQ-MON-03			x	x

5.15 Factory reset and data portability

5.15.1 Overview

This clause addresses the requirements in the CRA [i.1] Annex I, Part I (2) (m).

5.15.2 REQ-DRT-01

5.15.2.1 Requirement

The product shall provide a function to remove all user data and settings, and provide a function to restore to its secure-by-default state.

5.15.2.2 Applicability

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.15.3 REQ-DRT-02

5.15.3.1 Requirement

The product shall support secure read of all user data and settings from the product via the operational environment.

5.15.3.2 Applicability

This requirement applies to products with the capability for the user to write data and/or settings that fall within the following use cases:

- UC-1-RESEARCH: not required
- UC-2-HOME: required
- UC-3-FLEET: required
- UC-4-IOT: required

5.15.4 Mapping of requirements to use cases

Table 5.15.4-1: Factory reset and data portability mapping to use cases

Requirements	UC-1	UC-2	UC-3	UC-4
REQ-DRT-01		x	x	x
REQ-DRT-02		x	x	x

6 Assessment criteria for compliance with technical requirements

6.1 Introduction

6.1.1 General

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of clause 5.

For each requirement defined in clause 5, the following clauses specify assessment criteria to determine if the technical requirement is met.

Each assessment criterion corresponds to one technical requirement defined in clause 5. The assessment criteria do not introduce requirements additional to those specified in clause 5.

The assessment criteria for each technical requirement are described using the following structure:

a) Requirement reference: identifies the technical requirement in clause 5 to which the assessment criterion applies.

b) Objective: identifies the security property or capability to be verified and the purpose of the assessment.

c) Preparation: identifies the environment, setup, preconditions, information and tools required to perform the assessment, as applicable. Preparation can include:

- the hardware, software and network configuration of the assessment environment;
- the product configuration and operational state;
- required user or machine-user accounts, roles, credentials, certificates or other test data;
- tools required to perform the assessment, identified by the capabilities necessary for the assessment; and
- product information or documentation necessary to prepare or perform the assessment.

d) Activities: specifies the assessment activities to be performed to verify compliance with the technical requirement. Depending on the requirement, these activities can include examination of product information, inspection of product configuration, functional testing, observation of runtime behaviour, analysis of software or binaries, vulnerability testing or penetration testing. Where assessment by examination of information or documentation is used, functional or technical verification is performed where necessary to establish that the documented security functionality is implemented by the product and operates as specified.

e) Verdict: specifies the conditions under which the assessment result is PASS or FAIL. The assessment result is PASS where the evidence obtained through the assessment activities demonstrates that the technical requirement is fulfilled. The assessment result is FAIL where the evidence demonstrates that the technical requirement is not fulfilled.

f) Evidence: identifies the evidence produced or collected during the assessment that supports the assessment verdict. Evidence can include, as applicable, assessment reports, test results, logs, configuration information, audit records, traffic captures, command or console output and relevant product or design documentation.

The evidence is sufficient to support independent verification of the assessment result.

Assessment criteria are identified by unique references to facilitate traceability between the technical requirements in clause 5 and the corresponding assessment criteria in the present clause.

6.1.2 Guidance for identifying interfaces or data processing

Some assessments require compiling a list of interfaces provided by or data processing done by the product. These are not limited to those described in accompanying product documentation, if any.

Some sources for compiling these lists may include, where available:

- documentation accompanying the product
- product technical documentation
- product functions
- product interfaces
- product configuration
- product metrics
- product logs
- product binaries
- product source code
- data transmitted by the product
- data stored by the product
- network scanners
- packet sniffers
- system bus scanners
- reverse-engineering tools
- penetration testing tools
- vulnerability testing tools
- manual testing
- custom test programs

6.2 Appropriate level of cybersecurity

6.2.1 Overview

This clause provides assessment for the requirements in clause 5.2 relating to CRA [i.1] Annex I, Part I (1).

6.2.2 REQ-ALC-01

6.2.2.1 Objective

Secure design and development.

6.2.2.2 Preparation

Identify all sources of untrusted input to the product. For each source of untrusted input, identify fields in the inputs that are used for:

- calculation of memory accesses: length, index, hash table lookup values, packet reassembly
- allocation of product resources: buffer length, number of packet descriptors, buffers for reassembly of fragmented packets, CPU-intensive cryptographic operations
- incrementing or decrementing of internal counters: packet counters, event counters
- creating or populating internal data structures: parameters for creating an array of packet descriptors

For each identified field, identify a set of inputs that contains at least one input that fulfils each of the following descriptions, if and only if the description is applicable to the field, the described values exist, and they are possible to send as input:

- the maximum **valid** value or length of input for that field
- the minimum **valid** value or length of input for that field
- the next value/length of input above the minimum valid value
- the next value/length of input below the minimum valid value
- the next value/length of input below the maximum valid value
- the next value/length of input above the maximum valid value
- the maximum **possible** value or length of input for that field
- the minimum **possible** value or length of input for that field
- the next value/length of input above the minimum possible value
- the next value/length of input below the maximum possible value
- a representative selection of other valid and invalid values or input lengths for that field
- values that could cause overflow or underflow of internal counters
- values that are inconsistent with other values in the input

Identify the acceptable behaviour(s) of the product in response to the inputs that would be consistent with validating the input and mitigating the cybersecurity risks of untrusted input. Identify a method of sending these inputs to the product and recording the responses. Set up this testing environment.

6.2.2.3 Activities

For every identified input, send the input to the product and record its response.

6.2.2.4 Verdict

PASS if for every identified input, the product responds in a manner consistent with the identified acceptable behaviour.

Otherwise FAIL

6.2.2.5 Evidence

- Description of identified fields of untrusted input
- Analysis of sources of untrusted input for identified inputs

- Sufficiency analysis of analysis of untrusted sources of input
- Description of test inputs and acceptable behaviours
- Logs of testing inputs and recording behaviour
- Sufficiency analysis of testing logs

6.2.2.6 Guidance

Assessment can often be done with minimal effort using commonly available fuzzer or security testing tools or adapting an existing product test suite. It can also be done by hand.

Examples of each of the types of input:

- calculation of memory accesses: length, index, hash table lookup values, packet reassembly
- allocation of product resources: buffer length, number of packet descriptors, buffers for reassembly of fragmented packets, CPU-intensive cryptographic operations
- incrementing or decrementing of internal counters: packet counters, event counters
- creating or populating internal data structures: parameters for creating an array of packet descriptors

The list of inputs to test includes some types of input that may not exist or be possible to send. For example, if the maximum **valid** value is also the maximum **possible** value, then it is not possible to send the next value higher than the maximum value. These values do not need to be tested.

Secure design and development practices such as static analysis or secure compilation flags may assist in the fulfilment of this requirement by identifying potential sources of untrusted input for review, as well as automatically validating and mitigating invalid values.

Acceptable behaviours might include:

- Rejection of input and returning an error
- Silent discard of input
- Correction of input
- Dropping client data and incrementing an error counter
- Emitting an error event
- Emitting a notification when a counter rolls over
- Crashing and restarting
- Terminating a thread

6.2.3 REQ-ALC-02

6.2.3.1 Objective

Appropriate level of cybersecurity.

6.2.3.2 Preparation

1) Initialize the product with the default configuration and required credentials.

6.2.3.3 Activities

1) Set the node and the chosen monitored element to a wrong time that is off by at least an hour;

2) Set a connected system service to a wrong time that deviates from real time by at least one hour.

6.2.3.4 Verdict

PASS if **all** of the following are fulfilled:

1) the product detects the drift, and

2) the product creates a notification about the event.

Otherwise FAIL

6.2.3.5 Evidence

- System notification from the logs.

6.3 No known exploitable vulnerabilities

6.3.1 Overview

This clause provides assessment for the requirements in clause 5.3 relating to CRA [i.1] Annex I, Part I (2) (a).

6.3.2 REQ-KEV-01

6.3.2.1 Objective

Prevent exploitation of known exploitable vulnerabilities.

6.3.2.2 Preparation

Using the product's SBOM and relevant publicly accessible vulnerability databases (e.g. GCVE, EUVD), compile a list of target components and potential known exploitable vulnerabilities. Select the appropriate testing methodology (e.g. the most comprehensive automated scanners available, or a manual penetration test plan) to verify the mitigation of these vulnerabilities.

6.3.2.3 Activities

On the product under assessment, carry out a security update, run the tests, and compare the results with the generated list of known exploitable vulnerabilities.

6.3.2.4 Verdict

PASS if **any** of the following are fulfilled:

- No vulnerabilities found, or
- all reported vulnerabilities satisfy either the elapsed time since discovery or mitigation requirement.

Otherwise FAIL

6.3.2.5 Evidence

- Documented vulnerability handling policy
- Product SBOM
- List of testing tools used or manual test plan
- Test reports/scan results

- Correlation of discovered vulnerabilities with:
  - documentation of mitigation, or
  - elapsed time since discovery of vulnerability.

6.4 Secure by default configuration

6.4.1 Overview

This clause provides assessment for the requirements in clause 5.4 relating to CRA [i.1] Annex I, Part I (2) (b).

No additional assessment is necessary for the requirements in this clause, as the included requirements are assessed in other clauses of the present document.

6.5 Security updates

6.5.1 Overview

This clause provides assessment for the requirements in clause 5.5 relating to CRA [i.1] Annex I, Part I (2) (c).

6.5.2 REQ-SU-01

6.5.2.1 Objective

Prevent exploitation of known exploitable vulnerabilities.

6.5.2.2 Preparation

Identify methods the product provides for installing updates. Identify an operational environment that permits testing these methods. Set up the product in the identified operational environment. Identify a method to verify the installation of an update. Identify an update that is not yet installed on the product.

6.5.2.3 Activities

Install the identified update for the product and use the identified method to verify it.

6.5.2.4 Verdict

PASS if verification of the installation of the update succeeds.

Otherwise FAIL

6.5.2.5 Evidence

- Logs of reading original and updated version of product
- Security update file(s)
- Logs of update installation process

6.5.2.6 Guidance

A method of assessment might be: install one version of the software, use a product-provided method of reading version of the installed product, then install a different version and read the version again.

6.6 Authentication and access control

6.6.1 Overview

This clause provides assessment for the requirements in clause 5.6 relating to CRA [i.1] Annex I, Part I (2) (d).

6.6.2 REQ-AAC-01

6.6.2.1 Objective

Prevent unauthorised access.

6.6.2.2 Preparation

Identify methods the product provides for authorisation or access control of cybersecurity-relevant product assets. Identify an operational environment that permits testing these methods. Identify product assets that require authentication or access control to protect the cybersecurity of the product. Identify any necessary configuration, inputs, or other preparation for testing authentication or access control for that asset. Set up the product in the identified operational environment.

6.6.2.3 Activities

For each method and each type of product asset identified, carry out the identified testing preparations and attempt to access the product asset without the necessary authorisation.

6.6.2.4 Verdict

PASS if every attempt to access the product asset without the necessary authorisation fails.

Otherwise FAIL

6.6.2.5 Evidence

- Descriptions of types of product assets requiring authorisation or access control
- Records of configuration, input, and/or preparation for each test
- Logs of access attempts and their results

6.7 Confidentiality protection

6.7.1 Overview

This clause provides assessment for the requirements in clause 5.7 relating to CRA [i.1] Annex I, Part I (2) (e).

6.7.2 REQ-CON-01

6.7.2.1 Objective

Protect the confidentiality of ingested data.

6.7.2.2 Preparation

Set up a monitored element and collect data from it.

6.7.2.3 Activities

Attempt to access the ingested data without valid authorisation.

6.7.2.4 Verdict

PASS if access is denied.

Otherwise FAIL

6.7.2.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement;

6.7.3 REQ-CON-02

6.7.3.1 Objective

Inform the user about the confidentiality protection of the sources of ingested data.

6.7.3.2 Preparation

None.

6.7.3.3 Activities

Set up a monitored element using a confidentiality-protected channel and collect data from it. Set up a monitored element using a channel without confidentiality protection and collect data from it. View, analyze, or otherwise make use of the data.

6.7.3.4 Verdict

PASS if at any point during the activities, the product informs the user that the non-confidentiality-protected data is not confidentiality protected.

Otherwise FAIL

6.7.3.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement;

6.7.3.6 Guidance

The product may distinguish the confidentiality of sources of data at the following times:

- addition of a monitored element
- display of monitoring data
- display of processed data
- in an alert

- in a report
- in a log message

6.7.4 REQ-CON-03

6.7.4.1 Objective

Protect the confidentiality of product secrets.

6.7.4.2 Preparation

Configure and use the product in a manner that results in stored secrets.

6.7.4.3 Activities

Attempt to read the stored secrets without valid authorisation. Then use valid authorisation to read the secrets as stored and attempt to decrypt them using materials available without valid authorisation.

6.7.4.4 Verdict

PASS if the stored secrets cannot be read without valid authorisation and cannot be decrypted using materials available without valid authorisation.

Otherwise FAIL

6.7.4.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.8 Integrity protection

6.8.1 Overview

This clause provides assessment for the requirements in clause 5.8 relating to CRA [i.1] Annex I, Part I (2) (f).

6.8.2 REQ-INT-01

6.8.2.1 Objective

Protect the integrity of ingested data.

6.8.2.2 Preparation

Set up a monitored element and collect data from it. Make a copy of the data.

6.8.2.3 Activities

Attempt to modify the ingested data without valid authorisation. Read the data and compare with the copy of the data taken before the attempt to modify it.

6.8.2.4 Verdict

PASS if the ingested data was not modified.

Otherwise FAIL

6.8.2.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement;

6.8.3 REQ-INT-02

6.8.3.1 Objective

Inform the user about the integrity protection of the sources of ingested data.

6.8.3.2 Preparation

None.

6.8.3.3 Activities

Set up a monitored element using an integrity-protected channel and collect data from it. Set up a monitored element using a channel without integrity protection and collect data from it. View, analyse, or otherwise make use of the data.

6.8.3.4 Verdict

PASS if at any point during the activities, the product informs the user that the non-integrity-protected data is not integrity protected.

Otherwise FAIL

6.8.3.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement;

6.8.3.6 Guidance

The product may distinguish the integrity of sources of data at the following times:

- addition of a monitored element
- display of monitoring data
- display of processed data
- in an alert
- in a report
- in a log message

6.8.4 REQ-INT-03

6.8.4.1 Objective

Protect the integrity of product secrets.

6.8.4.2 Preparation

Configure and use the product in a manner that results in stored secrets. Make a copy of the stored secrets.

6.8.4.3 Activities

Attempt to modify the stored secrets without valid authorisation. Read the stored secrets and compare with the copy of the stored secrets taken before the attempt to modify it.

6.8.4.4 Verdict

PASS if the stored secrets are not modified without valid authorisation.

Otherwise FAIL

6.8.4.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement;

6.9 Data minimisation

6.9.1 Overview

This clause provides assessment for the requirements in clause 5.9 relating to CRA [i.1] Annex I, Part I (2) (g).

6.9.2 REQ-DM-01

6.9.2.1 Objective

Minimise data processed by the product.

6.9.2.2 Preparation

Determine all data processing done by the product, using as necessary:

- product technical documentation
- product functions
- product interfaces
- data transmitted by the product
- data stored by the product
- product binaries
- source code

- other sources of product information

6.9.2.3 Activities

For each type of data processing identified, analyse its relevance and necessity for the intended purpose of the product.

6.9.2.4 Verdict

PASS if, for every type of data processing identified, the data processed is determined to be relevant and limited to what is necessary for the intended purpose of the product.

Otherwise FAIL

6.9.2.5 Evidence

- Product information used to determine what data processing the product does
- Sufficiency analyses of relevance, limitation, and necessity of data for product purpose

6.9.2.6 Guidance

Data processed should have a clear connection to the intended purpose of the product. Some examples:

- Collected log data
- Metrics
- Internal events
- Performance data
- Debug logs

6.10 Availability protection

6.10.1 Overview

This clause provides assessment for the requirements in clause 5.10 relating to CRA [i.1] Annex I, Part I (2) (h).

6.10.2 REQ-AP-01

6.10.2.1 Objective

Maintain service availability during denial-of-service attacks.

6.10.2.2 Preparation

None

6.10.2.3 Activities

Assess the technical documentation provided with the product.

6.10.2.4 Verdict

PASS if the technical documentation describes how the availability protection can be provided by the operational environment.

Otherwise FAIL

6.10.2.5 Evidence

- Documentation
- Analysis of documentation
- Documentation of intended purpose

6.10.3 REQ-AP-02

6.10.3.1 Objective

Protect availability of the product.

6.10.3.2 Preparation

Configure the product and monitored elements as necessary to be able to trigger activity that exceeds the product's data ingest processing when the elements are actively producing ingest data.

6.10.3.3 Activities

Trigger the activity that exceeds the product's data ingest processing. Record the alerts and logs from the product.

6.10.3.4 Verdict

PASS if the product outputs a log message or security alert for the dropped ingest data.

Otherwise FAIL

6.10.3.5 Evidence

- Description of test setup
- Logs from product with dropped ingest data annotated

6.10.4 REQ-AP-03

6.10.4.1 Objective

Protect availability of the product.

6.10.4.2 Preparation

Configure the product and monitored elements as necessary to be able to trigger activity that exceeds the product's data ingest processing when the elements are actively producing ingest data. Additionally configure a well-behaved monitored element to be able to trigger activity that requires less than its share of the total data ingest capacity of the product as configured, proportionate to the number of total monitored elements.

6.10.4.3 Activities

Trigger the activity of all configured elements.

6.10.4.4 Verdict

PASS if the data from the well-behaved monitored element is fully recorded by the product, or if any data is dropped, an event is recorded indicating the lost data.

Otherwise FAIL

6.10.4.5 Evidence

- Description of test setup
- Logs from product
- Analysis of proportion of data ingested from well-behaved monitored element
- Analysis of events recording data dropped from well-behaved monitored element
- Sufficiency analysis of analysis of proportion of data ingested
- Sufficiency analysis of analysis of events recording data dropped

6.10.5 REQ-AP-04

6.10.5.1 Objective

Maintain service availability during denial-of-service attacks.

6.10.5.2 Preparation

Identify input fields from untrusted input that are used to calculate the size of memory allocations, and create a set of inputs that, if processed as fast as possible, would significantly degrade the function of the product due to over-allocation of memory.

6.10.5.3 Activities

For each set of inputs,

1) send the input to the product,
2) while simultaneously measuring the availability of the product functions and the functions of the underlying platform.

6.10.5.4 Verdict

PASS if **all** of the following are fulfilled:

For each set of inputs,

- the product functions, and
- the platform functions remain acceptably available.

Otherwise FAIL

6.10.5.5 Evidence

- Set of inputs
- Logs of measurements
- Explanation of availability metrics

6.11 Non-interference

6.11.1 Overview

This clause provides assessment for the requirements in clause 5.11 relating to CRA [i.1] Annex I, Part I (2) (i).

6.11.2 REQ-NI-01

6.11.2.1 Objective

Minimise negative impact on other devices or services.

6.11.2.2 Preparation

Identify interfaces that may transmit data originating from the product itself in reply to incoming data to addresses that have not been verified as requesting the transmitted data. Identify network input that may cause the interface to transmit data in such a manner.

6.11.2.3 Activities

For each identified network input, transmit the input to the interface and record any data the product transmits in response. Analyse the amount of data sent in response in the context of the product function and cybersecurity risk assessment.

6.11.2.4 Verdict

PASS if the response is consistent with reasonable minimisation of data in the response.

Otherwise FAIL

6.11.2.5 Evidence

- Description of identified interfaces
- Description of methods for identifying interfaces
- Sufficiency analysis of methods for identifying interfaces
- Description of identified inputs
- Packet captures or other appropriate logs of the data transmitted
- Sufficiency analysis of analysis of amount of data in response

6.12 Attack surface minimisation

6.12.1 Overview

This clause provides assessment for the requirements in clause 5.12 relating to CRA [i.1] Annex I, Part I (2) (j).

6.12.2 REQ-ASM-01

6.12.2.1 Objective

Minimise attack surface.

6.12.2.2 Preparation

Identify all exposed interfaces in the product in its secure-by-default configuration, including different run-time states such as initial configuration, startup, in use, idle, shutdown, and reset, if applicable. Use appropriate tools and methodology to search for interfaces that may have been accidentally or unintentionally exposed and that could reasonably be found by a threat actor under the conditions of the manufacturer's cybersecurity risk assessment.

6.12.2.3 Activities

For each identified interface, analyse whether the exposure of the interface is necessary for the product's intended purpose in its secure-by-default configuration, connecting it to specific product functions and comparing with any obvious reasonable alternatives with a smaller attack surface.

6.12.2.4 Verdict

PASS if for each identified exposed interface, the analysis for exposure of the interface concludes that it is necessary and that there is no obvious reasonable alternative with a smaller attack surface.

Otherwise FAIL

6.12.2.5 Evidence

- Documentation of and rationale for search process for interfaces
- Logs of searches for interfaces
- Description of identified interfaces
- Sufficiency analysis of rationale for interface search process
- Analysis of necessity of and alternatives to each identified interface
- Sufficiency analysis of necessity analysis for identified exposed interfaces

6.12.2.6 Guidance

See clause 6.1.2 "Guidance for identifying interfaces or data processing."

6.13 Exploit mitigation

6.13.1 Overview

This clause provides assessment for the requirements in clause 5.13 relating to CRA [i.1] Annex I, Part I (2) (k).

6.13.2 REQ-EM-01

6.13.2.1 Objective

Detect compromise of monitored elements.

6.13.2.2 Preparation

Set up a monitored element that regularly emits data.

6.13.2.3 Activities

Prevent the monitored element from providing ingest data to the product and observe if the product emits a notification or alert.

6.13.2.4 Verdict

PASS if the product emits a notification or alert of the loss of the monitored element's ingested data.

Otherwise FAIL

6.13.2.5 Evidence

- Logs of the monitored element's ingest data
- Logs of product notifications or alerts

6.14 Monitoring

6.14.1 Overview

This clause provides assessment for the requirements in clause 5.14 relating to CRA [i.1] Annex I, Part I (2) (l).

6.14.2 REQ-MON-01

6.14.2.1 Objective

Monitoring and recording cybersecurity-relevant events.

6.14.2.2 Preparation

Review the technical documentation to confirm the scope of cybersecurity-relevant events implemented in the logging mechanism.

6.14.2.3 Activities

For each type of cybersecurity-relevant event, trigger the event, and collect any log messages.

6.14.2.4 Verdict

PASS if for each triggered event, a log message is emitted that records the cybersecurity-relevant elements of the event.

Otherwise FAIL

6.14.2.5 Evidence

- Method of triggering events
- Logs of triggering events and generated log messages
- Log messages with annotations
- Sufficiency analysis of annotated log messages

6.14.3 REQ-MON-02

6.14.3.1 Objective

Protect the confidentiality of internal log data.

6.14.3.2 Preparation

Use the product in a manner that produces internal log data.

6.14.3.3 Activities

Attempt to access the internal log data without valid authorisation.

6.14.3.4 Verdict

PASS if access is denied.

Otherwise FAIL

6.14.3.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.14.4 REQ-MON-03

6.14.4.1 Objective

Protect the integrity of internal log data.

6.14.4.2 Preparation

Use the product in a manner that produces internal log data. Set a log retention policy that prevents alteration or deletion of logs.

6.14.4.3 Activities

Attempt to modify and delete the internal log data without valid authorisation.

6.14.4.4 Verdict

PASS if both modification and deletion fail.

Otherwise FAIL

6.14.4.5 Evidence

- Test reports showing the steps performed and results obtained;
- Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
- Logs, configuration files, or audit traces demonstrating the implementation of the requirement.

6.15 Factory reset and data portability

6.15.1 Overview

This clause provides assessment for the requirements in clause 5.15 relating to CRA [i.1] Annex I, Part I (2) (m).

6.15.2 REQ-DRT-01

6.15.2.1 Objective

Secure deletion of all user data and settings.

6.15.2.2 Preparation

Identify every type of stored data or setting that may be changed by the user on the product, how to store it on the product, and how to read it from the product. Identify a method to securely delete user data and settings and reset the product to its secure-by-default state.

6.15.2.3 Activities

For each type of user data or setting that may be stored and changed by the user on the product:

1) record the value of the setting in the secure-by-default configuration of the product

2) write an instance of the data or setting stored on the product that is different from the default

Once all types of user data or settings have been written and read, use the identified method to delete all user data and settings and reset to a secure-by-default configuration. Record the value of each type of user data or setting again. Compare with the original records for each type of user data or setting in its secure-by-default state.

6.15.2.4 Verdict

PASS if **all** of the following are fulfilled:

- All user data and settings tested have been deleted, and
- All settings tested are restored to a secure-by-default state.

Otherwise FAIL

6.15.2.5 Evidence

- Description of each type of user data or setting written
- For each type, record of original value, written value, and value after deletion and reset to secure-by-default method
- Comparison and analysis of different values
- Sufficiency analysis of comparison

6.15.2.6 Guidance

Some user settings or data (e.g. dates, randomly generated values, installation logs) may differ harmlessly between different secure-by-default configurations, so a direct comparison of the initial and final values may show some differences in a conforming product.

6.15.3 REQ-DRT-02

6.15.3.1 Objective

Secure reading of data.

6.15.3.2 Preparation

Identify every type of stored data or setting that may be changed by the user on the product, how to store it on the product, and how to read it from the product using confidentiality protection provided by the operational environment.

6.15.3.3 Activities

For each type of user data or setting that may be stored and changed by the user on the product:

1) record the value of the setting in the secure-by-default configuration of the product

2) write an instance of the data or setting stored on the product that is different from the default

Once all types of user data or settings have been written and read, use the identified method to read all user data and settings. While transferring the data, attempt to read or modify it without the authorisation or access necessary for the confidentiality protection provided by the operational environment. Compare with written value and the original records for each type of user data or setting in its secure-by-default state.

6.15.3.4 Verdict

PASS if all user data and settings read are consistent with the user data and settings written, and the attempts to read or modify the data fail.

Otherwise FAIL

6.15.3.5 Evidence

- Description of each type of user data or setting written
- For each type, record of original value, written value, and read value
- Comparison and analysis of values
- Sufficiency analysis of comparison

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Table A.1: Relationship between the present document and the requirements of Regulation (EU) 2024/2847 - the Cyber Resilience Act

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (1)	"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."	Clause 5.2 Clause 6.2	
Annex I, Part I, (2)(a)	"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."	Clause 5.3 Clause 6.3	
Annex I, Part I, (2)(b)	"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."	Clause 5.4 Clause 6.4	
Annex I, Part I, (2)(c)	"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them"	Clause 5.5 Clause 6.5	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(d)	"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access"	Clause 5.6 Clause 6.6	
Annex I, Part I, (2)(e)	"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."	Clause 5.7 Clause 6.7	
Annex I, Part I, (2)(f)	"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."	Clause 5.8 Clause 6.8	
Annex I, Part I, (2)(g)	"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."	Clause 5.9 Clause 6.9	
Annex I, Part I, (2)(h)	"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."	Clause 5.10 Clause 6.10	
Annex I, Part I, (2)(i)	"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."	Clause 5.11 Clause 6.11	
Annex I, Part I, (2)(j)	"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."	Clause 5.12 Clause 6.12	
Annex I, Part I, (2)(k)	"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."	Clause 5.13 Clause 6.13	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(l)	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	Clause 5.14 Clause 6.14	
Annex I, Part I, (2)(m)	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	Clause 5.15 Clause 6.15	

Key to columns:

Description A textual reference to the requirement.

Requirements of Regulation

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

Clause(s) of the present document

Identification of clause(s) addressing the requirement in the present document

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Security analysis

B.0 Overview

This Annex applies state of the art methodology to identify assets, threats, identify and evaluate risk factors, and define security profiles applicable to the different use cases identified in the product context.

The security analysis in this Annex represents a risk assessment done by the standardisers solely for the purpose of informing the applicability of technical requirements.

A list of product assets is used to identify potential threats to the product. The assumptions are used to define the scope of potential threats that are addressed by this security analysis.

Risk factor levels for each use case are determined by using the definition of the use case to choose a risk factor level that most accurately represents the highest risk for that use case. The use case is restricted by the intended purpose and reasonably foreseeable use as specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat. This security analysis uses the Likelihood and Impact of each threat to identify specific technical requirements that treat that risk.

B.1 Assets

B.1.1 Data

SIEM client:

- SIEM client executable
- Configuration of SIEM client
- Cryptographic materials
- Logs and metrics

SIEM server:

- SIEM server executable
- Catalogue of monitored elements
- Collected data
- Configuration
- Cryptographic materials
- Logs and metrics (for the product itself)

B.1.2 Hardware

- Server hardware for on-premises deployment

B.1.3 Product and monitored element functions

- Receives/scrapes logs and metrics from monitored elements
- Filters and correlates monitoring data

- Creates alerts or notifications of anomalies
- Provides reports, visualisation, or other support to operators

B.2 Risk factors

B.2.1 Overview

Risk factor levels determine the impact and likelihood of each threat in this security analysis. Risk factor levels also specify which requirements reduce the risk of each threat to satisfy all technical cybersecurity requirements in clause 5.

Risk factors may increase the likelihood of an incident, increase the impact of an incident, or both. As a result, different mitigation strategies may be more or less relevant to different risk factors.

The overall risk related to each use case should be considered as a result of combining risk factors affecting both likelihood and impact of an incident.

B.2.2 [RF-NET] Accessibility of the network connected to product assets

Description: How publicly accessible the network is that the product and its assets are connected to.

Rationale: The more unrestricted the access to the connected networks is, the more likely a threat actor can compromise the product via the network.

- **[RF-NET-L-LOW]** Foreseeable use is only in an isolated private network
- **[RF-NET-L-MED]** Foreseeable use is in a private network with filtered connection to public network
- **[RF-NET-L-HI]** Foreseeable use is in a public network

B.2.3 [RF-FUN] Sensitivity of product function

Description: Measures the impact of compromise of product functions.

Rationale: The impact of an attack on the product includes the impact it has on the monitored assets.

- **[RF-SMA-L-LOW]** Little or no impact of loss of product function, such as the compromise of a small number of unimportant devices
- **[RF-SMA-L-MED]** Moderate impact of compromise of product function, such as temporary loss of some services
- **[RF-SMA-L-HI]** High impact of compromise of product function, such as loss of primary business function

B.2.4 [RF-NUM] Number of monitored elements

Description: How many elements are monitored by the product.

Rationale: A larger number of elements increases the attack surface and the consequences of an attack.

- **[RF-L-LOW]** Low number of monitored elements, such as in a home lab
- **[RF-L-MED]** Moderate number of monitored elements, such as in a single data centre
- **[RF-L-HI]** High number of monitored elements, such as in a nation-wide telco infrastructure

B.2.5 [RF-ADM] Availability and skill of administration

Description: What the availability and skill of administration is for the product.

Rationale: Skilled, fully resourced administration allows more risk transfer and can reduce the impact of incidents.

Type: Affects likelihood and impact of all attacks.

- **[ADM-L-LO]** Foreseeable use is with fully resourced professional administration
- **[ADM-L-MED]** Foreseeable use is with professional administration with limited resources
- **[ADM-L-HI]** Foreseeable use is with unskilled or no administration

B.3 Assumptions

B.3.1 Overview

Assumptions are used to define the scope of the potential threats addressed by this analysis.

B.3.2 Proper platform

The platform the product is running on is trustworthy.

B.3.3 Proper administrator

The product administrator is not intentionally hostile and is engaging in good faith efforts to administer the product properly.

B.3.4 Attacker expends resources proportionate to product assets

An attacker will use limited resources in proportion to the value of the assets of the product in each use case.

B.4 Threats and security analysis of threats

B.4.1 General

The approach to listing threats is to separate them by mitigation so that they may be associated with mitigations more directly.

B.4.2 Security analysis methodology

Risk factor levels for each use case are determined by reading the descriptions for each risk factor level and choosing the one that most accurately represents the highest risk for the intended purpose and reasonably foreseeable use of the product, as specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat, on a scale of Very Low, Low, Medium, and High.

For each threat, both likelihood and impact need to be Very Low before the risk is considered sufficiently mitigated. If the calculated levels are not already Very Low, then mitigations need to be applied until they are both Very Low. The set of requirements that will accomplish this are listed in each threat description.

For some threats, the risk analysis assigns the same requirements to treat more than one level of risk. When this occurs, it is because the same mitigation treats more than levels of risk and there is no lesser mitigation that treats the lower risk(s) but not the higher risk(s). Risk formulas like this could be simplified, but keeping the distinction between levels of risk may simplify the addition of new mitigations for lower risk cases.

B.4.3 List of threats, risk assessments, and mitigations

B.4.3.1 TH-UEVU: Unknown exploitable vulnerabilities

Attacker may use unknown exploitable vulnerabilities in the product to harm the product's assets.

Risk formula	Likelihood	Use cases
NET is Low	Very Low	RESEARCH
NET is Medium and NUM is Low	Low	HOME
all others	Medium	FLEET
NET is High and NUM is high	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

- Low to Very Low:
  - REQ-ALC-01
  - REQ-ASM-01
- Medium to Very Low:
  - REQ-ALC-01
  - REQ-ALC-02
  - REQ-ASM-01
- High to Very Low:
  - REQ-ALC-01
  - REQ-ALC-02
  - REQ-ASM-01

Mitigations for Impact:

- Low to Very Low:
  - REQ-DM-01
  - REQ-MON-01
  - REQ-MON-02
- Medium to Very Low:
  - REQ-DM-01
  - REQ-EM-01
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-DM-01
  - REQ-EM-01
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.4.3.2 TH-KEVU: Known exploitable vulnerabilities

Attacker may use known exploitable vulnerabilities in the product implementation to get unauthorised access to product assets.

Risk formula	Likelihood	Use cases
NET is Low and ADM is Low	Very Low	RESEARCH
NET is Low and ADM is not Low	Low	HOME
all others	Medium	FLEET
NET is High	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

- Low to Very Low:
  - REQ-KEV-01
  - REQ-SU-01
- Medium to Very Low:
  - REQ-KEV-01
  - REQ-SU-01
- High to Very Low:
  - REQ-KEV-01
  - REQ-SU-01

Mitigations for Impact:

- Low to Very Low:
  - REQ-DM-01
  - REQ-MON-01
- Medium to Very Low:
  - REQ-DM-01
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-DM-01
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.4.3.3 TH-CACC: Circumvention of access control

Attacker may get unauthorised access to product assets by exploiting gaps or weaknesses in authorisation or access control.

Risk formula	Likelihood	Use cases
NET is Low and ADM is Low	Very Low	RESEARCH
NET is Medium and ADM is Low	Low	FLEET
all others	Medium	HOME
NET is High and NUM is high	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

- Low to Very Low:
  - REQ-AAC-01
- Medium to Very Low:
  - REQ-AAC-01
- High to Very Low:
  - REQ-AAC-01

Mitigations for Impact:

- Low to Very Low:
  - REQ-MON-01
- Medium to Very Low:
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.4.3.4 TH-DSTP: Unauthorised access to data stored via used product

Attacker may get unauthorised access to confidential data stored on the product through acquisition of a used platform containing the product.

Risk formula	Likelihood	Use cases
NUM is Low and ADM is Low	Very Low	RESEARCH
NUM is Low and ADM is Medium	Low	None
all others	Medium	HOME, FLEET
NUM is High and ADM is more than Low	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

- Low to Very Low:
  - REQ-DRT-01
  - REQ-DRT-02
- Medium to Very Low:
  - REQ-DRT-01
  - REQ-DRT-02
- High to Very Low:
  - REQ-DRT-01
  - REQ-DRT-02

Mitigations for Impact:

- Low to Very Low:
  - REQ-CON-01
- Medium to Very Low:
  - REQ-CON-01
  - REQ-CON-03
- High to Very Low:
  - REQ-CON-01
  - REQ-CON-03

B.4.3.5 TH-UADT: Unauthorised access to data transmitted or stored

Attacker may use access to the connected network to compromise the confidentiality or integrity of data transmitted by the product.

Risk formula	Likelihood	Use cases
NET is Low and ADM is Low	Very Low	RESEARCH
NET is Low and ADM is not Low	Low	HOME
all others	Medium	FLEET
NET is High	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

- Low to Very Low:
  - REQ-CON-01
  - REQ-INT-01
  - REQ-INT-03
- Medium to Very Low:
  - REQ-CON-01
  - REQ-CON-02
  - REQ-INT-01
  - REQ-INT-02
  - REQ-INT-03
- High to Very Low:
  - REQ-CON-01
  - REQ-CON-02
  - REQ-CON-03
  - REQ-INT-01
  - REQ-INT-02
  - REQ-INT-03

Mitigations for Impact:

- Low to Very Low:
  - REQ-DM-01
  - REQ-MON-01
- Medium to Very Low:
  - REQ-DM-01
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-DM-01
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.4.3.6 TH-CONF: Access to assets via configuration errors

Attacker may use unintentional configuration errors to get unauthorised access to the product assets.

Risk formula	Likelihood	Use cases
NET is Low	Very Low	RESEARCH
NET is Medium and ADM is Low	Low	FLEET
all others	Medium	HOME
NET is High and ADM is more than Low	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

NOTE: See Clause 5.4 Secure by default configuration

- Low to Very Low:
  - REQ-ASM-01
- Medium to Very Low:
  - REQ-ASM-01
- High to Very Low:
  - REQ-ASM-01

Mitigations for Impact:

- Low to Very Low:
  - REQ-MON-01
- Medium to Very Low:
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.4.3.7 TH-AVAI: Denial of service attack on product

Attacker may use network access to product to reduce availability of product functions.

Risk formula	Likelihood	Use cases
NET is Low	Very Low	RESEARCH
NET is Medium and FUN is Low	Low	HOME
all others	Medium	FLEET
NET is High	High	IOT

Risk formula	Impact	Use cases
FUN is Low and NUM is Low	Very Low	RESEARCH
FUN is Medium and NUM is Low	Low	HOME
all others	Medium	IOT
FUN is High and NUM is High	High	FLEET

Mitigations for Likelihood:

NOTE: See Clause 5.10 Availability protection

- Low to Very Low:
  - REQ-AP-01
- Medium to Very Low:
  - REQ-AP-01
  - REQ-AP-02
  - REQ-AP-03
  - REQ-AP-04
- High to Very Low:
  - REQ-AP-01
  - REQ-AP-02
  - REQ-AP-03
  - REQ-AP-04

Mitigations for Impact:

- Low to Very Low:
  - REQ-MON-01
- Medium to Very Low:
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.4.3.8 TH-DDOS: Interference with other devices

Attacker may use product functions to interfere with other devices or services.

Risk formula	Likelihood	Use cases
NET is Low	Very Low	RESEARCH
NET is Medium and ADM is Low	Low	FLEET
all others	Medium	HOME
NET is High	High	IOT

Risk formula	Impact	Use cases
NET is Low	Very Low	RESEARCH
NET is Medium and NUM is Low	Low	HOME
all others	Medium	FLEET
NET is High and NUM is High	High	IOT

Mitigations for Likelihood:

- Low to Very Low:
  - REQ-NI-01
- Medium to Very Low:
  - REQ-NI-01
  - REQ-NI-02
- High to Very Low:
  - REQ-NI-01
  - REQ-NI-02

Mitigations for Impact:

- Low to Very Low:
  - REQ-MON-01
- Medium to Very Low:
  - REQ-MON-01
  - REQ-MON-02
- High to Very Low:
  - REQ-MON-01
  - REQ-MON-02
  - REQ-MON-03

B.5 Mapping of risk factors to use cases

Table B.5-1: Mapping of all use cases to risk factors

Use case	NET	FUN	NUM	ADM
UC-1-RESEARCH	Low	Low	Low	Low
UC-2-HOME	Medium	Medium	Low	High
UC-3-FLEET	Medium	High	High	Low
UC-4-IOT	High	Medium	High	Medium

Annexes C to J:
Void

Annex K (normative): Generic cryptographic requirements and assessment

K.1 Cryptography

K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

1) ACM-listed: the cryptographic mechanism is listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [reference];

2) ACM-extended: the cryptographic mechanism is not listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [reference] and meets at least one of the following conditions:

   a) the cryptographic mechanism is listed in clause K.3.2 as an ACM-extended cryptographic mechanism for the specific product function(s);

   b) where the cryptographic mechanism is not listed in clause K.3.2, the cryptographic mechanism meets all the following criteria:

      i) the cryptographic mechanism, or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [reference];

      ii) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognised European, international or sector-specific standards development organisation, or by an industry specification organisation accountable for the relevant specification: ISO, IEC, IETF, IEEE, ETSI, CEN, CENELEC or NIST *;* or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognised national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process: the BSI TR-02102 series [i.7], [i.8], [i.9], [i.10] or ANSSI RGS Annex B [i.11];

      iii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;

      iv) the cryptographic properties of the cryptographic mechanism are known;

      v) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;

      vi) the cryptographic mechanism is required for a specific set of product functions;

   c) Interoperability-based: the cryptographic mechanism is listed in clause K.4.2 as an interoperability-based cryptographic mechanism for specific product function(s) and external specification(s) or external requirement(s).

NOTE 1: The reference to the product's default configuration is intended to define a clear and assessable baseline, corresponding to the configuration in which the product is placed on the market. The product can provide several configurations that fulfil the requirement.

NOTE 2: For products supplied as hardware platforms or components to be configured by an integrator, references in this annex to the product's default configuration refer to the configuration specified for the intended operational use of the product after integration, including the relevant integration assumptions and configuration constraints.

NOTE 3: The applicable ACM catalogue version is identified in the normative references of the present document. The lifecycle treatment of mechanisms affected by ACM deprecation dates, expiry dates, migration conditions or usage limitations is addressed in clause K.2.

NOTE 4: In this clause, an external specification or external requirement means a specification or requirement that is imposed on the product, and which requires the use of a specific cryptographic mechanism for the product to interoperate with an identified system, platform or operational context. An external requirement can be a regulatory requirement, operational constraint, technical interoperability constraint, or platform compatibility requirement.

NOTE 5: Inclusion of a cryptographic mechanism under the interoperability-based criterion does not classify that mechanism as state-of-the-art cryptography.

EXAMPLE: Examples of product functions include secure communication based on TLS 1.3; authenticated encryption of communicated data based on AES-GCM; storage confidentiality based on AES-XTS; firmware signature verification based on Ed25519; and key derivation based on HKDF.

K.1.2 Assessment of product cryptographic configuration

K.1.2.0 General

The assessment in clause K.1.2 verifies the cryptographic mechanisms used in the product's default configuration against clause K.1.1.

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in clause K.3.2 or fulfils the criteria specified in clause K.1.1 item 2.b. For interoperability-based cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is listed in clause K.4.2. The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

K.1.2.1 Assessment of ACM-listed cryptographic mechanisms

K.1.2.1.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 1) and used in the product's default configuration are listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

K.1.2.1.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

K.1.2.1.3 Assessment activities

The assessment shall include verification that:

a) each cryptographic mechanism claimed under clause K.1.1 item 1) is identified by reference to a relevant ACM entry;

b) the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;

c) where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

K.1.2.1.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) description of the product's default configuration;

b) list of cryptographic mechanisms claimed under clause K.1.1 item 1);

c) references to the relevant ACM entries;

d) relevant parameters, profiles, cipher suites or configuration constraints, where applicable;

e) relevant lifecycle information from the ACM catalogue, where applicable.

K.1.2.1.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 1).
- The verdict FAIL shall be assigned otherwise.

K.1.2.2 Assessment of ACM-extended cryptographic mechanisms

K.1.2.2.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in clause K.3.2 or fulfil the criteria specified in clause K.1.1 item 2.b, and are used for the claimed product function(s).

K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following:

    a) the relevant entry in clause K.3.2; or

    b) evidence that the cryptographic mechanism fulfils all applicable criteria in clause K.1.1 item 2.b.

K.1.2.2.3 Assessment activities

The assessment shall include verification that:

a) each cryptographic mechanism claimed under clause K.1.1 item 2) is either listed in clause K.3.2 as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in clause K.1.1 item 2.b;

b) the cryptographic mechanism used by the product corresponds to the mechanism listed in clause K.3.2 or described in the evidence provided under clause K.1.1 item 2.b;

c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.3.2 or justified under clause K.1.1 item 2.b;

d) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.3.2 or justified under clause K.1.1 item 2.b, where applicable;

e) where clause K.3.2 or the justification under clause K.1.1 item 2.b defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;

f) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) description of the product's default configuration;

b) list of cryptographic mechanisms claimed under clause K.1.1 item 2);

c) reference to the relevant entry in clause K.3.2, where the mechanism is listed in clause K.3.2;

d) evidence that the cryptographic mechanism fulfils the criteria in clause K.1.1 item 2.b, where compliance with clause K.1.1 item 2 is claimed on the basis of those criteria;

e) identification of the related product function using the cryptographic mechanism and the use case where applicable;

f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;

g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.3.2 or in the justification under clause K.1.1 item 2.b, where applicable.

K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 2).
- The verdict FAIL shall be assigned otherwise.

K.1.2.3 Assessment of interoperability-based cryptographic mechanisms

K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 3) and used in the product's default configuration are listed as interoperability-based cryptographic mechanisms in clause K.4.2 and are used in accordance with the characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in clause K.4.2.

K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 3), including the related product function, use case where applicable, relevant parameters where applicable, the external specification or external requirement requiring its use, and the relevant entry in clause K.4.2.

K.1.2.3.3 Assessment activities

The assessment shall include verification that:

a) each cryptographic mechanism claimed under clause K.1.1 item 3) is listed in clause K.4.2 as an interoperability-based cryptographic mechanism;

b) the cryptographic mechanism used by the product corresponds to the cryptographic mechanism listed in clause K.4.2;

c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.4.2;

d) the external specification or external requirement requiring the use of the cryptographic mechanism corresponds to the external specification or external requirement specified in clause K.4.2;

e) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.4.2, where applicable;

f) the conditions or limitations specified in clause K.4.2 for the use of the cryptographic mechanism are reflected in the product's default configuration;

g) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) description of the product's default configuration;

b) list of cryptographic mechanisms claimed under clause K.1.1 item 3);

c) reference to the relevant entry in clause K.4.2;

d) identification of the related product function using the cryptographic mechanism and the use case where applicable;

e) identification of the external specification or external requirement requiring use of the cryptographic mechanism;

f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;

g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.4.2.

K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 3).
- The verdict FAIL shall be assigned otherwise.

NOTE 1: The assessment of the external specification or external requirement itself is outside the scope of this assessment case. The assessment verifies that the external specification or external requirement is identified in clause K.4.2 and that the cryptographic mechanism is used by the product for the related product function.

NOTE 2: Documentation review is a minimum assessment activity under the present annex. Functional and/or resistance testing activities can be added by vertical standards where relevant for the product category, product function or cryptographic mechanism.

K.2 Crypto agility

K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

a) updating the cryptographic mechanism;

b) using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;

c) disabling the use of the affected cryptographic mechanism; or

d) limiting the use of the affected product functions accordingly.

EXAMPLE: Where a security mechanism uses a hybrid cryptographic construction, for example a hybrid key-encapsulation mechanism combining a classical and a post-quantum primitive, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization can be used as part of a planned migration strategy where permitted by the ACM catalogue or by the present document. However, hybridization does not, by itself, extend the recommended usage lifetime of a constituent primitive that has been deprecated.

NOTE 1: Where a hybrid cryptographic construction includes multiple cryptographic primitives, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridization is not assumed to mitigate the deprecation of a constituent primitive unless the ACM catalogue or the present document classifies the hybrid construction as suitable for the corresponding product function.

NOTE 2: Crypto agility supports maintaining appropriate cryptographic protection within the intended lifetime of the product, in addition to the capability of updating cryptographic mechanisms on the product in accordance with secure update and secure communication mechanisms.

NOTE 3: Deprecation information from sources other than the ACM catalogue or the present document can be considered as input to vulnerability management or security risk assessment but does not by itself trigger the requirement in clause K.2.1.

NOTE 4: Where the product provides cryptographic capabilities for use by other products, components or layers, the mechanism required by clause K.2.1 can consist of update, configuration, disabling, deprecation or limitation capabilities usable by the integrating product, system operator or user, where applicable.

NOTE 5: The applicability condition of this requirement can express exceptions based on product characteristics, e.g. cryptographic implementation based on immutable hardware co-processor(s) or hardware-based root of trust, or long-lived silicon used in a long-lived non-updateable environment.

K.2.2 Assessment of crypto-agility

K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with clause K.2.1.

K.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall identify:

    a) the intended lifetime of the product;

    b) the cryptographic mechanisms used in the product's default configuration;

    c) the related product function(s) for each cryptographic mechanism;

    d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

K.2.2.3 Assessment activities

The assessment shall include verification that:

a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;

b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;

c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism, or limiting the use of the affected product functions accordingly;

d) where another cryptographic mechanism is used, that cryptographic mechanism complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

a) documentation of the intended lifetime of the product;

b) list of cryptographic mechanisms used in the product's default configuration;

c) identification of the related product function(s) for each cryptographic mechanism;

d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;

e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;

f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism, or limitation of the use of the affected product functions.

K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.2.1.
- The verdict FAIL shall be assigned otherwise.

K.3 ACM-extended cryptographic mechanisms

K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in clause K.1.1 item 2.

K.3.2 List of ACM-extended cryptographic mechanisms

No ACM-extended cryptographic mechanisms are specified by the present document.

K.3.3 Assessment

Compliance with the ACM-extended criterion in clause K.1.1 item 2 is assessed in clause K.1.2.2.

K.4 Interoperability-based cryptographic mechanisms

K.4.1 Requirement

Where the product's default configuration uses interoperability-based cryptographic mechanisms, these mechanisms shall be selected from the interoperability-based cryptographic mechanisms listed in clause K.4.2 for the specified product functions and external specifications or external requirements and shall be used in accordance with the conditions or limitations specified in clause K.4.2.

K.4.2 List of interoperability-based cryptographic mechanisms

No interoperability-based cryptographic mechanisms are specified by the present document.

K.4.3 Assessment

Compliance with the requirement in clause K.4.1 is assessed in clause K.1.2.3.

NOTE: The assessment of the external specifications or external requirements themselves is outside the scope of this assessment. Their relevance is deemed confirmed by their inclusion in the present document.

Annexes L to Q:
Void

Annex R (normative): Additional provisions for products relying on Remote Data Processing Solutions (RDPS)

R.1 Scope and applicability

This annex specifies additional technical requirements and assessment provisions for products with digital elements that rely on Remote Data Processing Solutions ("RDPS") for the provision or support of one or more product functions.

The requirements applicable to the product functions themselves remain specified in the core part of the concerned standard and continue to apply to the product as a whole, including where a product function is performed locally, supported by an RDPS, or performed in part through an RDPS.

This annex specifies supplementary requirements and assessment provisions for the product-facing RDPS boundary, i.e. for the additional attack surface, interactions, and dependency conditions introduced where a product function is performed or supported across the local product side and the RDPS side.

Where the product does not rely on remote data processing solutions for the provision or support of any product function, this annex is not applicable.

This annex does not extend to the full remote service environment or underlying third-party infrastructure, except to the extent necessary to define assumptions, dependencies, and assessment conditions relevant to the product-facing RDPS boundary and the secure operation of the RDPS-dependent product function.

R.2 RDPS as a product-boundary extension

When a product relies on RDPS for the provision or support of one or more product functions, the use of RDPS is considered, for the purposes of the present annex, to introduce an additional product-facing boundary and interface between the local product side and the RDPS side.

The present annex does not restate or replace the requirements applicable to the product function as such. It specifies only the supplementary requirements needed to address the increased attack surface introduced by the RDPS boundary.

The present annex therefore addresses the security implications introduced by that additional boundary and interface, including:

1) the exchanged interactions across the RDPS boundary;

2) the relevant product-side and RDPS-side endpoints; and

3) the dependency conditions arising where the secure operation of the product function relies on interactions across that boundary.

The scope of the present annex is limited to the RDPS interface between the local product side and the RDPS side. For the purposes of the present annex:

- *local product side* means the product elements within the product boundary that participate in the interaction with the RDPS;
- RDPS means the remote data processing solution performing or supporting operations relevant to the RDPS-dependent product function;
- *RDPS interface* means the communication boundary between the product-side endpoint and the RDPS-side endpoint.

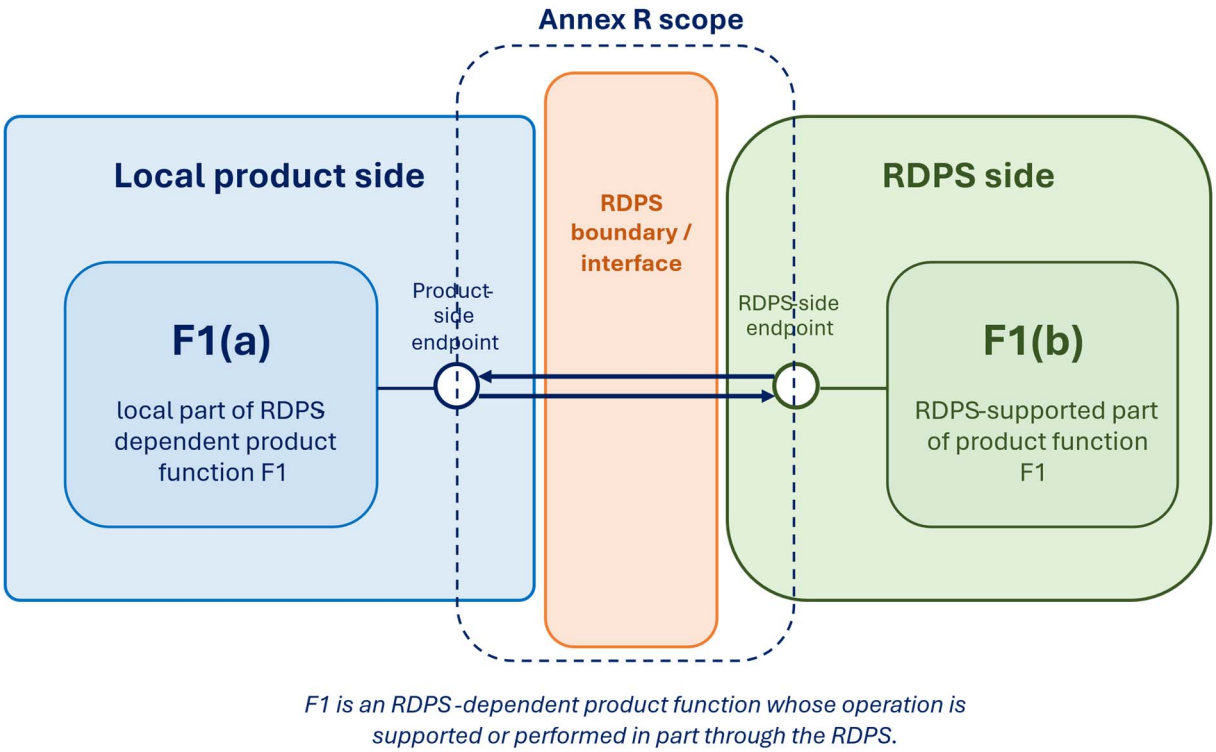


Figure R.2-1: RDPS model for Annex R — scope focused on the product ↔ RDPS boundary

R.3 Threat model

This clause does not restate or replace threats for local product components that are already defined in the main clauses of the standard. Instead, it focuses on:

- threats introduced by the local product-RDPS interface, and
- threats introduced by the RDPS as a remote service capability.

The threat model:

- identifies RDPS assets; and
- defines a set of threats applicable to RDPS.

R.3.1 Assets

The threat model considers the following assets:

DA-RDPS-001 - RDPS interaction content: The information exchanged across the RDPS boundary, including, as applicable, requests, commands, responses, decisions, configuration data, secrets, update-related data, and personal data where such data is exchanged.

For the purposes of DA-RDPS-001, Table R.3.1-1 identifies potential categories of RDPS interaction content and indicates the security properties to be considered for each category when determining the applicable Annex R requirement families.

Table R.3.1-1: Security properties for DA-RDPS-001

Content type	Data authenticity	Integrity	Confidentiality
Commands / requests & Responses / decisions	X	X	
Configuration data	X	X	
Secrets (e.g., keys)	X	X	X
Code or update data	X	X	
Confidential code or update data	X	X	X
Personal data	X	X	X

NOTE: In Table R.3.1-1, "data authenticity" refers to the authenticity or trusted origin of the exchanged interaction content. It does not refer to authentication of the RDPS boundary endpoint.

DA-RDPS-002 - RDPS-dependent product function: product function for which one or more operations depend on an RDPS, including the associated security-relevant state, decisions, outputs, or configuration.

For the purposes of *DA-RDPS-002*, Table R.3.1-2 identifies the security property relevant to the RDPS-dependent product function.

Table R.3.1-2: Security property for DA-RDPS-002

Content type	Availability
RDPS-dependent product function	X

R.3.2 Threat catalogue

The following threats constitute the baseline threat set considered for the RDPS boundary within the scope of Annex R, covering the RDPS interaction content exchanged across the boundary and the availability of the RDPS-dependent product function.

T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary

An attacker causes an endpoint to accept interaction content across the RDPS boundary whose claimed source or origin is not genuine.

Threat type: Spoofing / impersonation

Security impact: The receiving endpoint may rely on interaction content that does not originate from the intended source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

T-RDPS-02 Loss of integrity of interactions across the RDPS boundary

An interaction exchanged across the RDPS boundary is modified, substituted, injected, corrupted, or replayed before it is processed by the receiving endpoint.

Threat type: Tampering

Security impact: The receiving endpoint may act upon interaction content whose contents no longer correspond to what was sent or intended by the legitimate source, which can affect the behaviour, state, configuration, or security of the RDPS-dependent product function.

T-RDPS-03 Unauthorised disclosure of interactions across the RDPS boundary

Data exchanged across the RDPS boundary is disclosed to an unauthorised party.

Threat type: Information disclosure

Security impact: An attacker may obtain interaction content whose disclosure can affect the security or secure operation of the RDPS-dependent product function.

T-RDPS-04 Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary

The local product side or the RDPS side is unable to send, receive, or process interactions across the RDPS boundary, or receives them only after an unacceptable delay, or experiences degradation of communication performance across the RDPS boundary to an extent that is not tolerable for the successful operation of the RDPS-dependent product function.

Threat type: Denial of service

Security impact: The RDPS-dependent product function may fail to operate as intended, may operate with incomplete, outdated, or degraded information, may remain blocked, or may continue without the required interaction being available when needed.

R.3.3 Mapping of assets to threats

Table R.3.3-1: Threats ↔ Assets mapping

Threat ID	Threat title	Related asset(s)
T-RDPS-01	Loss of data authenticity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-02	Loss of integrity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-03	Unauthorised disclosure of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-04	Unavailability, unacceptable delay, or intolerable degradation of interactions across the RDPS boundary	DA-RDPS-002

R.4 Security requirements

R.4.1 General and guidance for requirement structure

The requirements in the present clause are organized by requirement family. The requirement families address the primary security properties identified for the assets in Clause R.3.1, namely data authenticity, integrity, confidentiality, and availability.

The present version of Annex R uses a three-level requirement structure: within each requirement family, the requirements are expressed as a sequence of requirements with increasing rigour. In this scenario, the lower-numbered requirement defines the baseline security outcome to be achieved, while the higher-numbered requirements define strengthened requirements for cases where increased protection is needed.

The applicable requirement or requirements within a given family are intended to be determined in accordance with the integration approach of the concerned standard, including any relevant use case, security profile, equivalent classification, or risk-based applicability model, together with the manufacturer's risk assessment for the product and the RDPS-dependent product function.

R.4.2 Applicability of Annex R requirements

The requirements in the present clause address the protection of the security properties identified for the assets in Clause R.3.1.

Where a security property is identified as relevant for a given asset in the asset tables of Clause R.3.1, the corresponding requirement family or families in the present clause shall be considered for applicability to that asset.

For *DA-RDPS-001*, the primary requirement families considered for applicability are:

1) data authenticity of interactions;
2) integrity of interactions; and
3) confidentiality of exchanged data.

For *DA-RDPS-002*, the primary requirement family considered for applicability is availability.

The requirements within a given requirement family represent alternative levels of rigour and are not cumulative. For each applicable requirement family, one applicable level shall be selected. Selection of a higher-numbered requirement within a family includes the security outcome of the lower-numbered requirement(s) in that family and does not require separate selection of those lower-numbered requirement(s).

R.4.3 Local product side requirements

R.4.3.1 Data authenticity of interactions received from the RDPS side

REQ-RDPS-L-AUTH-001: The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction originates from the intended RDPS-side endpoint.

Rationale: This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

REQ-RDPS-L-AUTH-002: The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the data authenticity of that interaction using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism that provides assurance of the origin of the interaction.

Rationale: This requirement strengthens protection against spoofed or falsely originated interaction content by requiring cryptographic assurance of origin.

REQ-RDPS-L-AUTH-003: The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that:

1) the cryptographic authenticity of the interaction is bound to the intended RDPS-side endpoint; and

2) replayed or stale interactions are detected and rejected where replay or reuse could affect the secure operation of the RDPS-dependent product function.

Rationale: This requirement provides stronger protection by requiring source-bound authenticity and replay protection.

R.4.3.2 Integrity of interactions received from the RDPS side

REQ-RDPS-L-INTEG-001: The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction has not been modified, substituted, corrupted, or injected.

Rationale: This requirement protects against loss of integrity of received interaction content.

REQ-RDPS-L-INTEG-002: The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the integrity of that interaction using a cryptographic integrity-protection mechanism.

Rationale: This requirement strengthens protection against unauthorised modification or substitution of received interactions.

REQ-RDPS-L-INTEG-003: The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

Rationale: This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source.

R.4.3.3 Confidentiality of data exchanged with the RDPS side

REQ-RDPS-L-CONF-001: Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall protect the confidentiality of that data during exchange with the RDPS side.

Rationale: Confidentiality is not required for every exchange. However, where disclosure of data exchanged with the RDPS side could affect the security or secure operation of the RDPS-dependent product function, confidentiality protection is required.

REQ-RDPS-L-CONF-002: Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall protect the confidentiality of that data during exchange with the RDPS side using cryptographic confidentiality protection.

Rationale: This requirement strengthens confidentiality protection by requiring cryptographic protection of exchanged data where disclosure would create unacceptable cybersecurity risk.

REQ-RDPS-L-CONF-003: Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall use cryptographic confidentiality protection that is established with the intended RDPS-side endpoint and that prevents disclosure of the exchanged data to endpoints other than that intended endpoint.

Rationale: This requirement provides stronger protection by ensuring that confidential exchanged data is disclosed only to the intended peer endpoint.

R.4.3.4 Availability

REQ-RDPS-L-AVAIL-001: Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

1) detect unavailability of the RDPS side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;

2) use timeout or equivalent timeliness controls for expected RDPS-side interactions; and

3) apply a defined behaviour for the RDPS-dependent product function.

Rationale: This requirement ensures that loss, delay, or degradation of RDPS-side interactions is detected and handled in a defined manner before it adversely affects the secure operation of the RDPS-dependent product function.

REQ-RDPS-L-AVAIL-002: Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

1) detect unavailability of the RDPS side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;

2) use timeout or equivalent timeliness controls for expected RDPS-side interactions;

3) apply a defined degraded behaviour or secure state when the required RDPS-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits; and

4) support recovery of the RDPS-dependent product function using locally maintained state, configuration, or other recovery information where such information is necessary to restore secure operation.

Rationale: This requirement strengthens protection by requiring controlled degraded operation or transition to a secure state, together with support for restoration of secure operation.

REQ-RDPS-L-AVAIL-003: Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

1) detect unavailability of the RDPS side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;

2) use timeout or equivalent timeliness controls for expected RDPS-side interactions;

3) apply a defined degraded behaviour or secure state when the required RDPS-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits;

4) support recovery of the RDPS-dependent product function using locally maintained state, configuration, or other recovery information where such information is necessary to restore secure operation;

5) support continuity of operation through failover, redundancy, or an equivalent resilience mechanism where such a mechanism is necessary.

Rationale: This requirement provides stronger protection by requiring resilience measures.

R.4.4 RDPS side requirements

R.4.4.1 Data authenticity of interactions received from the local product side

REQ-RDPS-R-AUTH-001: The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction originates from the intended local product-side endpoint.

Rationale: This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

REQ-RDPS-R-AUTH-002: The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the data authenticity of that interaction using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism that provides assurance of the origin of the interaction.

Rationale: This requirement strengthens protection against spoofed or falsely originated interaction content by requiring cryptographic assurance of origin.

REQ-RDPS-R-AUTH-003: The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that:

1) the cryptographic authenticity of the interaction is bound to the intended local product-side endpoint; and

2) replayed or stale interactions are detected and rejected where replay or reuse could affect the secure operation of the RDPS-dependent product function.

Rationale: This requirement provides stronger protection by requiring source-bound authenticity and replay protection.

R.4.4.2 Integrity of interactions received from the local product side

REQ-RDPS-R-INTEG-001: The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction has not been modified, substituted, corrupted, or injected.

Rationale: This requirement protects against loss of integrity of received interaction content.

REQ-RDPS-R-INTEG-002: The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, the integrity of that interaction using a cryptographic integrity-protection mechanism.

Rationale: This requirement strengthens protection against unauthorised modification or substitution of received interactions.

REQ-RDPS-R-INTEG-003: The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration, or security of the RDPS-dependent product function, that the interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

Rationale: This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source.

R.4.4.3 Confidentiality of data exchanged with the local product side

REQ-RDPS-R-CONF-001: Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side.

Rationale: This requirement ensures confidentiality where disclosure of exchanged data could affect the security or secure operation of the RDPS-dependent product function.

REQ-RDPS-R-CONF-002: Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side using cryptographic confidentiality protection.

Rationale: This requirement strengthens confidentiality protection by requiring cryptographic protection during exchange.

REQ-RDPS-R-CONF-003: Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall use cryptographic confidentiality protection that is established with the intended local product-side endpoint and that prevents disclosure of the exchanged data to endpoints other than that intended endpoint.

Rationale: This requirement provides stronger protection by ensuring that confidential exchanged data is disclosed only to the intended peer endpoint.

R.4.4.4 Availability

REQ-RDPS-R-AVAIL-001: Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

1) detect unavailability of the local product side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;

2) use timeout or equivalent timeliness controls for expected local product-side interactions; and

3) apply a defined behaviour for the RDPS-dependent product function.

Rationale: This requirement ensures that loss, delay, or degradation of local product-side interactions is detected and handled in a defined manner before it adversely affects the secure operation of the RDPS-dependent product function.

REQ-RDPS-R-AVAIL-002: Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

1) detect unavailability of the local product side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;

2) use timeout or equivalent timeliness controls for expected local product-side interactions;

3) apply a defined degraded behaviour or secure state when the required local product-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits; and

4) support recovery of the RDPS-dependent product function using maintained state, configuration, or other recovery information where such information is necessary to restore secure operation.

Rationale: This requirement strengthens protection by requiring controlled degraded operation or transition to a secure state, together with support for restoration of secure operation.

REQ-RDPS-R-AVAIL-003: Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

1) detect unavailability of the local product side, unacceptable delay of expected interactions, or intolerable degradation of the interaction;

2) use timeout or equivalent timeliness controls for expected local product-side interactions;

3) apply a defined degraded behaviour or secure state when the required local product-side interactions are unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits;

4) support recovery of the RDPS-dependent product function using maintained state, configuration, or other recovery information where such information is necessary to restore secure operation;

5) support continuity of operation through failover, redundancy, or an equivalent resilience mechanism where such a mechanism is necessary.

Rationale: This requirement provides stronger protection by requiring resilience measures.

R.4.5 Mapping of threats to requirements

Table R.4.5-1: Threats ↔ Requirements mapping

Threat ID	Requirement(s) - Local product side	Requirement(s) – RDPS side
T-RDPS-01	REQ-RDPS-L-AUTH-001	REQ-RDPS-R-AUTH-001
T-RDPS-01	REQ-RDPS-L-AUTH-002	REQ-RDPS-R-AUTH-002
T-RDPS-01	REQ-RDPS-L-AUTH-003	REQ-RDPS-R-AUTH-003
T-RDPS-02	REQ-RDPS-L-INTEG-001	REQ-RDPS-R-INTEG-001
T-RDPS-02	REQ-RDPS-L-INTEG-002	REQ-RDPS-R-INTEG-002
T-RDPS-02	REQ-RDPS-L-INTEG-003	REQ-RDPS-R-INTEG-003
T-RDPS-03	REQ-RDPS-L-CONF-001	REQ-RDPS-R-CONF-001
T-RDPS-03	REQ-RDPS-L-CONF-002	REQ-RDPS-R-CONF-002
T-RDPS-03	REQ-RDPS-L-CONF-003	REQ-RDPS-R-CONF-003
T-RDPS-04	REQ-RDPS-L-AVAIL-001	REQ-RDPS-R-AVAIL-001
T-RDPS-04	REQ-RDPS-L-AVAIL-002	REQ-RDPS-R-AVAIL-002
T-RDPS-04	REQ-RDPS-L-AVAIL-003	REQ-RDPS-R-AVAIL-003

R.5 Conformity assessment

The assessment cases in the present clause are aligned with the requirements in clause R.4. Each assessment case follows a common structure: assessment reference, assessment objective, assessment preparation, assessment activities, assessment verdict, and assessment evidence.

R.5.1 Local product side requirements

R.5.1.1 Assessment case for REQ-RDPS-L-AUTH-001

1) Assessment reference
Requirement: REQ-RDPS-L-AUTH-001

2) Assessment objective
The objective of the assessment is to verify that the local product side verifies, before acting upon a relevant received interaction, that the interaction originates from the intended RDPS-side endpoint.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the interactions received from the RDPS side that can influence the behaviour, state, configuration, or security of that function;
- the intended RDPS-side endpoint for those interactions; and
- the mechanism used by the local product side to determine the origin of the received interaction.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the mechanism used by the local product side to determine the origin of the relevant interaction;
- verify that the origin of the interaction is checked before the interaction is acted upon;
- verify that interactions from the intended RDPS-side endpoint are accepted; and
- verify that interactions not originating from the intended RDPS-side endpoint are rejected or not acted upon.

5) Assessment verdict
PASS:

- the local product side verifies the origin of the relevant interaction before acting upon it; and
- interactions from endpoints other than the intended RDPS-side endpoint are rejected or not acted upon.

FAIL:

- the local product side acts upon a relevant interaction without verifying its origin; or
- the local product side accepts and acts upon a relevant interaction not originating from the intended RDPS-side endpoint.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design or configuration evidence describing how origin of the interaction is determined;
- evidence showing acceptance of interactions from the intended RDPS-side endpoint; and
- evidence showing rejection or non-processing of interactions from other endpoints.

R.5.1.2 Assessment case for REQ-RDPS-L-AUTH-002

1) Assessment reference
Requirement: REQ-RDPS-L-AUTH-002

2) Assessment objective
The objective of the assessment is to verify that the local product side verifies the data authenticity of relevant received interactions using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism providing assurance of origin.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the cryptographic mechanism used to provide assurance of origin; and
- the conditions under which the local product side accepts or rejects those interactions.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic mechanism used to provide assurance of origin;
- verify that the local product side checks the authenticity-protection status of the interaction before acting upon it;
- verify that a valid interaction protected by the intended mechanism is accepted; and
- verify that an interaction lacking valid cryptographic assurance of origin is rejected or not acted upon.

5) Assessment verdict
PASS:

- the local product side uses a cryptographic mechanism providing assurance of origin for relevant received interactions;
- the local product side verifies that protection before acting upon the interaction; and
- interactions without valid assurance of origin are rejected or not acted upon.

FAIL:

- the local product side acts upon a relevant interaction without verifying cryptographic assurance of origin; or
- the local product side accepts and acts upon an interaction for which the required authenticity mechanism is absent or invalid.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic authenticity mechanism;
- traces or logs showing successful acceptance of valid protected interactions; and
- traces or logs showing rejection or non-processing of interactions without valid assurance of origin.

R.5.1.3 Assessment case for REQ-RDPS-L-AUTH-003

1) Assessment reference
Requirement: REQ-RDPS-L-AUTH-003

2) Assessment objective
The objective of the assessment is to verify that the local product side verifies that the cryptographic authenticity of the received interaction is bound to the intended RDPS-side endpoint and that replayed or stale interactions are detected and rejected where replay or reuse could affect secure operation.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the mechanism used to bind authenticity to the intended RDPS-side endpoint; and
- the replay or freshness protection mechanism, where applicable.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds the authenticity of the interaction to the intended RDPS-side endpoint;
- inspect the design and configuration of the freshness, anti-replay, or equivalent mechanism used;
- verify that a valid interaction bound to the intended RDPS-side endpoint is accepted;
- verify that an interaction with valid-looking authenticity protection but not bound to the intended RDPS-side endpoint is rejected or not acted upon; and
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

5) Assessment verdict
PASS:

- the local product side verifies that authenticity is bound to the intended RDPS-side endpoint; and
- replayed or stale interactions are rejected where replay or reuse could affect secure operation.

FAIL:

- the local product side accepts and acts upon an interaction whose cryptographic authenticity is not bound to the intended RDPS-side endpoint; or

- the local product side fails to detect and reject replayed or stale interactions where such protection is required.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for source binding and anti-replay/freshness controls;
- evidence showing acceptance of valid bound interactions; and
- evidence showing rejection of misbound, replayed, or stale interactions.

R.5.1.4 Assessment case for REQ-RDPS-L-INTEG-001

1) Assessment reference
Requirement: REQ-RDPS-L-INTEG-001

2) Assessment objective
The objective of the assessment is to verify that the local product side checks that a relevant received interaction has not been modified, substituted, corrupted, or injected before acting upon it.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the mechanism used by the local product side to detect modification, substitution, corruption, or injection.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the integrity-checking mechanism;
- verify that integrity is checked before the interaction is acted upon;
- verify that an unmodified valid interaction is accepted; and
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

5) Assessment verdict
PASS:

- the local product side checks the integrity of relevant received interactions before acting upon them; and
- modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

FAIL:

- the local product side acts upon a relevant interaction without verifying its integrity; or
- the local product side accepts and acts upon an altered, substituted, corrupted, or injected interaction.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design or configuration evidence of the integrity-checking mechanism;
- evidence showing acceptance of valid interactions; and
- evidence showing rejection or non-processing of altered or injected interactions.

R.5.1.5 Assessment case for REQ-RDPS-L-INTEG-002

1) Assessment reference
Requirement: REQ-RDPS-L-INTEG-002

2) Assessment objective
The objective of the assessment is to verify that the local product side verifies the integrity of relevant received interactions using a cryptographic integrity-protection mechanism.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the cryptographic integrity-protection mechanism used for those interactions.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic integrity-protection mechanism;
- verify that integrity verification takes place before the interaction is acted upon;
- verify that a valid cryptographically protected interaction is accepted; and
- verify that an interaction with missing or invalid integrity protection is rejected or not acted upon.

5) Assessment verdict
PASS:

- the local product side uses cryptographic integrity protection for relevant received interactions;
- integrity verification is performed before the interaction is acted upon; and
- interactions with invalid or missing integrity protection are rejected or not acted upon.

FAIL:

- the local product side does not use cryptographic integrity verification where required; or
- the local product side accepts and acts upon an interaction whose integrity protection is missing or invalid.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic integrity mechanism;
- evidence showing acceptance of valid protected interactions; and
- evidence showing rejection of interactions with invalid or missing integrity protection.

R.5.1.6 Assessment case for REQ-RDPS-L-INTEG-003

1) Assessment reference
Requirement: REQ-RDPS-L-INTEG-003

2) Assessment objective
The objective of the assessment is to verify that the local product side verifies that the relevant received interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the authenticated source of those interactions; and
- the mechanism used to bind integrity protection to that authenticated source.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds integrity protection to the authenticated source;
- verify that a valid interaction whose integrity protection is correctly bound to the authenticated source is accepted;
- verify that an interaction with integrity protection not bound to the authenticated source is rejected or not acted upon; and
- verify that integrity verification and source binding checks are performed before the interaction is acted upon.

5) Assessment verdict
PASS:

- the local product side verifies that the interaction is protected by cryptographic integrity protection bound to the authenticated source; and
- interactions not correctly bound to that source are rejected or not acted upon.

FAIL:

- the local product side accepts and acts upon a relevant interaction whose integrity protection is not bound to the authenticated source; or
- the local product side acts upon the interaction before performing the required checks.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for integrity binding to authenticated source;
- evidence showing acceptance of correctly bound interactions; and
- evidence showing rejection of misbound interactions.

R.5.1.7 Assessment case for REQ-RDPS-L-CONF-001

1) Assessment reference
Requirement: REQ-RDPS-L-CONF-001

2) Assessment objective
The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side protects the confidentiality of that data during exchange with the RDPS side.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk; and

- the mechanism used by the local product side to protect confidentiality during exchange.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the confidentiality-protection mechanism;
- verify that the identified data is protected during exchange with the RDPS side; and
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

5) Assessment verdict
PASS:

- the local product side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk; and
- such data is not exchanged in an unprotected manner.

FAIL:

- the local product side does not protect the confidentiality of exchanged data where such protection is required; or
- identified confidential data is exchanged without appropriate confidentiality protection.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design or configuration evidence identifying the protected data and the means of protection; and
- evidence showing that relevant exchanged data is protected during exchange.

R.5.1.8 Assessment case for REQ-RDPS-L-CONF-002

1) Assessment reference
Requirement: REQ-RDPS-L-CONF-002

2) Assessment objective
The objective of the assessment is to verify that the local product side protects the confidentiality of relevant exchanged data using cryptographic confidentiality protection.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring confidentiality protection; and
- the cryptographic confidentiality-protection mechanism used during exchange.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality-protection mechanism;
- verify that the identified exchanged data is protected by that mechanism during exchange; and
- verify that exchange of such data without the required cryptographic confidentiality protection is prevented.

5) Assessment verdict
PASS:

- relevant exchanged data is protected using cryptographic confidentiality protection; and
- exchange without the required cryptographic protection is prevented.

FAIL:

- the local product side exchanges relevant confidential data without cryptographic confidentiality protection; or
- the configured confidentiality mechanism is not effectively applied to the relevant data exchange.

6) Assessment evidence The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic confidentiality mechanism; and
- evidence showing protected exchange of the relevant data.

R.5.1.9 Assessment case for REQ-RDPS-L-CONF-003

1) Assessment reference
Requirement: REQ-RDPS-L-CONF-003

2) Assessment objective
The objective of the assessment is to verify that the local product side uses cryptographic confidentiality protection established with the intended RDPS-side endpoint and preventing disclosure of exchanged data to endpoints other than that intended endpoint.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring stronger confidentiality protection;
- the intended RDPS-side endpoint; and
- the cryptographic mechanism used to establish confidentiality protection with that endpoint.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality mechanism and its association with the intended RDPS-side endpoint;
- verify that protected exchange is established with the intended RDPS-side endpoint;
- verify that the local product side does not disclose the protected data to other endpoints under the same exchange context; and
- verify that exchanges not established with the intended RDPS-side endpoint are rejected or do not result in disclosure of the protected data.

5) Assessment verdict
PASS:

- confidentiality protection is established with the intended RDPS-side endpoint;
- protected data is disclosed only to that intended endpoint; and
- exchanges with other endpoints do not result in disclosure of the protected data.

FAIL:

- the local product side discloses protected data without establishing confidentiality protection with the intended RDPS-side endpoint; or
- the local product side discloses the protected data to endpoints other than the intended RDPS-side endpoint.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for endpoint-associated confidentiality protection;
- evidence showing protected disclosure to the intended RDPS-side endpoint; and
- evidence showing prevention of disclosure to other endpoints.

R.5.1.10 Assessment case for REQ-RDPS-L-AVAIL-001

1) Assessment reference
Requirement: REQ-RDPS-L-AVAIL-001

2) Assessment objective
The objective of the assessment is to verify that the local product side detects unavailability, unacceptable delay, or intolerable degradation of required RDPS-side interactions, uses timeout or equivalent timeliness controls, and applies a defined behaviour for the RDPS-dependent product function.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the acceptable timing or service conditions for those interactions; and
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the timeout, timeliness, or equivalent detection controls;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur; and
- verify that, under normal conditions, expected interactions are processed without triggering the fault-handling behaviour.

5) Assessment verdict
PASS:

- the local product side detects the specified failure, delay, or degradation conditions;
- timeout or equivalent timeliness controls are used; and
- a defined behaviour is applied when the identified conditions occur.

FAIL:

- the local product side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour is not applied when such a condition occurs.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for detection and timeliness controls;
- evidence showing detection of failure, delay, or degradation; and
- evidence showing application of the defined behaviour.

R.5.1.11 Assessment case for REQ-RDPS-L-AVAIL-002

1) Assessment reference
Requirement: REQ-RDPS-L-AVAIL-002

2) Assessment objective
The objective of the assessment is to verify that the local product side applies a defined degraded behaviour or secure state when required RDPS-side interactions are unavailable, delayed, or degraded, and supports recovery of the RDPS-dependent product function where needed.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the degraded behaviour or secure state defined for failure conditions; and
- any locally maintained state, configuration, or other recovery information required to restore secure operation.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the degraded behaviour or secure-state mechanism;
- inspect the design and configuration of the recovery mechanism, where applicable;
- verify that when required interactions become unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits, the local product side applies the defined degraded behaviour or secure state; and
- verify that recovery support is available and can be used to restore secure operation where such support is required.

5) Assessment verdict
PASS:

- the local product side applies the defined degraded behaviour or secure state under the relevant failure conditions; and
- recovery support is available and usable where necessary to restore secure operation.

FAIL:

- the local product side does not apply the defined degraded behaviour or secure state under the relevant failure conditions; or
- required recovery support is absent or ineffective.

6) Assessment evidence The following evidence may be used to support the assessment:

- design and configuration evidence for degraded behaviour, secure state, and recovery support; and
- evidence showing activation of degraded behaviour / secure state and restoration of secure operation where applicable.

R.5.1.12 Assessment case for REQ-RDPS-L-AVAIL-003

1) Assessment reference
Requirement: REQ-RDPS-L-AVAIL-003

2) Assessment objective
The objective of the assessment is to verify that the local product side supports higher resilience, including continuity of operation through failover, redundancy, or equivalent resilience mechanisms where necessary.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the defined degraded behaviour or secure state;
- the recovery support; and
- the failover, redundancy, or equivalent resilience mechanism, where required.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the resilience mechanism used to support continuity of operation;
- verify that the defined degraded behaviour or secure state is applied under the relevant failure conditions;
- verify that recovery support is available where required;
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

5) Assessment verdict
PASS:

- the local product side supports the required resilience mechanism where necessary;
- defined degraded behaviour or secure state is applied under the relevant conditions; and
- continuity of operation is supported in accordance with the design where resilience is required.

FAIL:

- a required resilience mechanism is absent or ineffective; or
- the local product side fails to support continuity of operation where such support is required.

6) Assessment evidence The following evidence may be used to support the assessment:

- design and configuration evidence for resilience, degraded behaviour, and recovery support; and
- evidence showing failover, redundancy, or equivalent continuity support where required.

R.5.2 RDPS side requirements

R.5.2.1 Assessment case for REQ-RDPS-R-AUTH-001

1) Assessment reference
Requirement: REQ-RDPS-R-AUTH-001

2) Assessment objective The objective of the assessment is to verify that the RDPS side verifies, before acting upon a relevant received interaction, that the interaction originates from the intended local product-side endpoint.

3) Assessment preparation Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the interactions received from the local product side that can influence the behaviour, state, configuration, or security of that function;
- the intended local product-side endpoint for those interactions; and

- the mechanism used by the RDPS side to determine the origin of the received interaction.

4) Assessment activities The assessment shall include the following activities:

- inspect the design and configuration of the mechanism used by the RDPS side to determine the origin of the relevant interaction;
- verify that the origin of the interaction is checked before the interaction is acted upon;
- verify that interactions from the intended local product-side endpoint are accepted; and
- verify that interactions not originating from the intended local product-side endpoint are rejected or not acted upon.

5) Assessment verdict
PASS:

- the RDPS side verifies the origin of the relevant interaction before acting upon it; and
- interactions from endpoints other than the intended local product-side endpoint are rejected or not acted upon.

FAIL:

- the RDPS side acts upon a relevant interaction without verifying its origin; or
- the RDPS side accepts and acts upon a relevant interaction not originating from the intended local product-side endpoint.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design or configuration evidence describing how origin of the interaction is determined;
- evidence showing acceptance of interactions from the intended local product-side endpoint; and
- evidence showing rejection or non-processing of interactions from other endpoints.

R.5.2.2 Assessment case for REQ-RDPS-R-AUTH-002

1) Assessment reference
Requirement: REQ-RDPS-R-AUTH-002

2) Assessment objective The objective of the assessment is to verify that the RDPS side verifies the data authenticity of relevant received interactions using cryptographic endpoint authentication, an authenticated communication channel, or an equivalent cryptographic mechanism providing assurance of origin.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the cryptographic mechanism used to provide assurance of origin; and
- the conditions under which the RDPS side accepts or rejects those interactions.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic mechanism used to provide assurance of origin;
- verify that the RDPS side checks the authenticity-protection status of the interaction before acting upon it;
- verify that a valid interaction protected by the intended mechanism is accepted; and

- verify that an interaction lacking valid cryptographic assurance of origin is rejected or not acted upon.

5) Assessment verdict
PASS:

- the RDPS side uses a cryptographic mechanism providing assurance of origin for relevant received interactions;
- the RDPS side verifies that protection before acting upon the interaction; and
- interactions without valid assurance of origin are rejected or not acted upon.

FAIL:

- the RDPS side acts upon a relevant interaction without verifying cryptographic assurance of origin; or
- the RDPS side accepts and acts upon an interaction for which the required authenticity mechanism is absent or invalid.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic authenticity mechanism;
- traces or logs showing successful acceptance of valid protected interactions; and
- traces or logs showing rejection or non-processing of interactions without valid assurance of origin.

R.5.2.3 Assessment case for REQ-RDPS-R-AUTH-003

1) Assessment reference
Requirement: REQ-RDPS-R-AUTH-003

2) Assessment objective The objective of the assessment is to verify that the RDPS side verifies that the cryptographic authenticity of the received interaction is bound to the intended local product-side endpoint and that replayed or stale interactions are detected and rejected where replay or reuse could affect secure operation.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the mechanism used to bind authenticity to the intended local product-side endpoint; and
- the replay or freshness protection mechanism, where applicable.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds the authenticity of the interaction to the intended local product-side endpoint;
- inspect the design and configuration of the freshness, anti-replay, or equivalent mechanism used;
- verify that a valid interaction bound to the intended local product-side endpoint is accepted;
- verify that an interaction with valid-looking authenticity protection but not bound to the intended local product-side endpoint is rejected or not acted upon; and
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

5) Assessment verdict
PASS:

- the RDPS side verifies that authenticity is bound to the intended local product-side endpoint; and
- replayed or stale interactions are rejected where replay or reuse could affect secure operation.

FAIL:

- the RDPS side accepts and acts upon an interaction whose cryptographic authenticity is not bound to the intended local product-side endpoint; or
- the RDPS side fails to detect and reject replayed or stale interactions where such protection is required.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for source binding and anti-replay/freshness controls;
- evidence showing acceptance of valid bound interactions; and
- evidence showing rejection of misbound, replayed, or stale interactions.

R.5.2.4 Assessment case for REQ-RDPS-R-INTEG-001

1) Assessment reference
Requirement: REQ-RDPS-R-INTEG-001

2) Assessment objective
The objective of the assessment is to verify that the RDPS side checks that a relevant received interaction has not been modified, substituted, corrupted, or injected before acting upon it.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the mechanism used by the RDPS side to detect modification, substitution, corruption, or injection.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the integrity-checking mechanism;
- verify that integrity is checked before the interaction is acted upon;
- verify that an unmodified valid interaction is accepted; and
- verify that modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

5) Assessment verdict
PASS:

- the RDPS side checks the integrity of relevant received interactions before acting upon them; and
- modified, substituted, corrupted, or injected interactions are rejected or not acted upon.

FAIL:

- the RDPS side acts upon a relevant interaction without verifying its integrity; or
- the RDPS side accepts and acts upon an altered, substituted, corrupted, or injected interaction.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design or configuration evidence of the integrity-checking mechanism;
- evidence showing acceptance of valid interactions; and
- evidence showing rejection or non-processing of altered or injected interactions.

R.5.2.5 Assessment case for REQ-RDPS-R-INTEG-002

1) Assessment reference
Requirement: REQ-RDPS-R-INTEG-002

2) Assessment objective
The objective of the assessment is to verify that the RDPS side verifies the integrity of relevant received interactions using a cryptographic integrity-protection mechanism.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the cryptographic integrity-protection mechanism used for those interactions.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic integrity-protection mechanism;
- verify that integrity verification takes place before the interaction is acted upon;
- verify that a valid cryptographically protected interaction is accepted; and
- verify that an interaction with missing or invalid integrity protection is rejected or not acted upon.

5) Assessment verdict
PASS:

- the RDPS side uses cryptographic integrity protection for relevant received interactions;
- integrity verification is performed before the interaction is acted upon; and
- interactions with invalid or missing integrity protection are rejected or not acted upon.

FAIL:

- the RDPS side does not use cryptographic integrity verification where required; or
- the RDPS side accepts and acts upon an interaction whose integrity protection is missing or invalid.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic integrity mechanism;
- evidence showing acceptance of valid protected interactions; and
- evidence showing rejection of interactions with invalid or missing integrity protection.

R.5.2.6 Assessment case for REQ-RDPS-R-INTEG-003

1) Assessment reference
Requirement: REQ-RDPS-R-INTEG-003

2) Assessment objective
The objective of the assessment is to verify that the RDPS side verifies that the relevant received interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the authenticated source of those interactions; and
- the mechanism used to bind integrity protection to that authenticated source.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds integrity protection to the authenticated source;
- verify that a valid interaction whose integrity protection is correctly bound to the authenticated source is accepted;
- verify that an interaction with integrity protection not bound to the authenticated source is rejected or not acted upon; and
- verify that integrity verification and source binding checks are performed before the interaction is acted upon.

5) Assessment verdict
PASS:

- the RDPS side verifies that the interaction is protected by cryptographic integrity protection bound to the authenticated source; and
- interactions not correctly bound to that source are rejected or not acted upon.

FAIL:

- the RDPS side accepts and acts upon a relevant interaction whose integrity protection is not bound to the authenticated source; or
- the RDPS side acts upon the interaction before performing the required checks.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for integrity binding to authenticated source;
- evidence showing acceptance of correctly bound interactions; and
- evidence showing rejection of misbound interactions.

R.5.2.7 Assessment case for REQ-RDPS-R-CONF-001

1) Assessment reference
Requirement: REQ-RDPS-R-CONF-001

2) Assessment objective
The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side protects the confidentiality of that data during exchange with the local product side.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk; and
- the mechanism used by the RDPS side to protect confidentiality during exchange.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the confidentiality-protection mechanism;
- verify that the identified data is protected during exchange with the local product side; and
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

5) Assessment verdict
PASS:

- the RDPS side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk; and
- such data is not exchanged in an unprotected manner.

FAIL:

- the RDPS side does not protect the confidentiality of exchanged data where such protection is required; or
- identified confidential data is exchanged without appropriate confidentiality protection.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design or configuration evidence identifying the protected data and the means of protection; and
- evidence showing that relevant exchanged data is protected during exchange.

R.5.2.8 Assessment case for REQ-RDPS-R-CONF-002

1) Assessment reference
Requirement: REQ-RDPS-R-CONF-002

2) Assessment objective
The objective of the assessment is to verify that the RDPS side protects the confidentiality of relevant exchanged data using cryptographic confidentiality protection.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring confidentiality protection; and
- the cryptographic confidentiality-protection mechanism used during exchange.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality-protection mechanism;
- verify that the identified exchanged data is protected by that mechanism during exchange; and
- verify that exchange of such data without the required cryptographic confidentiality protection is prevented.

5) Assessment verdict
PASS:

- relevant exchanged data is protected using cryptographic confidentiality protection; and
- exchange without the required cryptographic protection is prevented.

FAIL:

- the RDPS side exchanges relevant confidential data without cryptographic confidentiality protection; or
- the configured confidentiality mechanism is not effectively applied to the relevant data exchange.

6) Assessment evidence The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic confidentiality mechanism; and
- evidence showing protected exchange of the relevant data.

R.5.2.9 Assessment case for REQ-RDPS-R-CONF-003

1) Assessment reference
Requirement: REQ-RDPS-R-CONF-003

2) Assessment objective
The objective of the assessment is to verify that the RDPS side uses cryptographic confidentiality protection established with the intended local product-side endpoint and preventing disclosure of exchanged data to endpoints other than that intended endpoint.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring stronger confidentiality protection;
- the intended local product-side endpoint; and
- the cryptographic mechanism used to establish confidentiality protection with that endpoint.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality mechanism and its association with the intended local product-side endpoint;
- verify that protected exchange is established with the intended local product-side endpoint;
- verify that the RDPS side does not disclose the protected data to other endpoints under the same exchange context; and
- verify that exchanges not established with the intended local product-side endpoint are rejected or do not result in disclosure of the protected data.

5) Assessment verdict
PASS:

- confidentiality protection is established with the intended local product-side endpoint;
- protected data is disclosed only to that intended endpoint; and
- exchanges with other endpoints do not result in disclosure of the protected data.

FAIL:

- the RDPS side discloses protected data without establishing confidentiality protection with the intended local product-side endpoint; or

- the RDPS side discloses the protected data to endpoints other than the intended local product-side endpoint.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for endpoint-associated confidentiality protection;
- evidence showing protected disclosure to the intended local product-side endpoint; and
- evidence showing prevention of disclosure to other endpoints.

R.5.2.10 Assessment case for REQ-RDPS-R-AVAIL-001

1) Assessment reference
Requirement: REQ-RDPS-R-AVAIL-001

2) Assessment objective
The objective of the assessment is to verify that the RDPS side detects unavailability, unacceptable delay, or intolerable degradation of required local product-side interactions, uses timeout or equivalent timeliness controls, and applies a defined behaviour for the RDPS-dependent product function.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the acceptable timing or service conditions for those interactions; and
- the defined behaviour to be applied when the required interactions are unavailable, delayed, or degraded.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the timeout, timeliness, or equivalent detection controls;
- verify that unavailability, unacceptable delay, or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur; and
- verify that, under normal conditions, expected interactions are processed without triggering the fault-handling behaviour.

5) Assessment verdict
PASS:

- the RDPS side detects the specified failure, delay, or degradation conditions;
- timeout or equivalent timeliness controls are used; and
- a defined behaviour is applied when the identified conditions occur.

FAIL:

- the RDPS side does not detect the relevant failure, delay, or degradation condition; or
- the required defined behaviour is not applied when such a condition occurs.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for detection and timeliness controls;
- evidence showing detection of failure, delay, or degradation; and

- evidence showing application of the defined behaviour.

R.5.2.11 Assessment case for REQ-RDPS-R-AVAIL-002

1) Assessment reference
Requirement: REQ-RDPS-R-AVAIL-002

2) Assessment objective
The objective of the assessment is to verify that the RDPS side applies a defined degraded behaviour or secure state when required local product-side interactions are unavailable, delayed, or degraded, and supports recovery of the RDPS-dependent product function where needed.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the degraded behaviour or secure state defined for failure conditions; and
- any maintained state, configuration, or other recovery information required to restore secure operation.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the degraded behaviour or secure-state mechanism;
- inspect the design and configuration of the recovery mechanism, where applicable;
- verify that when required interactions become unavailable, delayed beyond the acceptable time, or degraded beyond acceptable limits, the RDPS side applies the defined degraded behaviour or secure state; and
- verify that recovery support is available and can be used to restore secure operation where such support is required.

5) Assessment verdict
PASS:

- the RDPS side applies the defined degraded behaviour or secure state under the relevant failure conditions; and
- recovery support is available and usable where necessary to restore secure operation.

FAIL:

- the RDPS side does not apply the defined degraded behaviour or secure state under the relevant failure conditions; or
- required recovery support is absent or ineffective.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for degraded behaviour, secure state, and recovery support; and
- evidence showing activation of degraded behaviour / secure state and restoration of secure operation where applicable.

R.5.2.12 Assessment case for REQ-RDPS-R-AVAIL-003

1) Assessment reference
Requirement: REQ-RDPS-R-AVAIL-003

2) Assessment objective
The objective of the assessment is to verify that the RDPS side supports higher resilience, including continuity of operation through failover, redundancy, or equivalent resilience mechanisms where necessary.

3) Assessment preparation
Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the defined degraded behaviour or secure state;
- the recovery support; and
- the failover, redundancy, or equivalent resilience mechanism, where required.

4) Assessment activities
The assessment shall include the following activities:

- inspect the design and configuration of the resilience mechanism used to support continuity of operation;
- verify that the defined degraded behaviour or secure state is applied under the relevant failure conditions;
- verify that recovery support is available where required;
- where failover, redundancy, or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed, or degraded.

5) Assessment verdict
PASS:

- the RDPS side supports the required resilience mechanism where necessary;
- defined degraded behaviour or secure state is applied under the relevant conditions; and
- continuity of operation is supported in accordance with the design where resilience is required.

FAIL:

- a required resilience mechanism is absent or ineffective; or
- the RDPS side fails to support continuity of operation where such support is required.

6) Assessment evidence
The following evidence may be used to support the assessment:

- design and configuration evidence for resilience, degraded behaviour, and recovery support; and
- evidence showing failover, redundancy, or equivalent continuity support where required.

R.6 Mapping of CRA Annex I to Annex R requirements

Table R.6-1 identifies the CRA Annex I Part I requirements that are directly relevant to the RDPS boundary and maps them to the corresponding Annex R requirements. The purpose of this mapping is to support manufacturer traceability and to identify directly relevant CRA requirements that are not yet fully covered by the current Annex R draft. Requirements not covered by Annex R remain addressed by the core part of the standard, insofar as they apply to the product as a whole.

Table R.6-1: CRA Annex I Part I to Annex R requirements mapping

Requirements of Regulation	Clause(s) of the present document
Annex I, Part I, (1)	REQ-RDPS-L-AUTH-001 to -003, REQ-RDPS-L-INTEG-001 to -003, REQ-RDPS-L-CONF-001 to -003, REQ-RDPS-L-AVAIL-001 to -003, REQ-RDPS-R-AUTH-001 to -003, REQ-RDPS-R-INTEG-001 to -003, REQ-RDPS-R-CONF-001 to -003, REQ-RDPS-R-AVAIL-001 to -003
Annex I, Part I, (2)(a)	Covered by the requirements in the core part of the standard
Annex I, Part I, (2)(b)	Covered by the requirements in the core part of the standard
Annex I, Part I, (2)(c)	Covered by the requirements in the core part of the standard
Annex I, Part I, (2)(d)	REQ-RDPS-L-AUTH-001 to -003 and REQ-RDPS-R-AUTH-001 to -003
Annex I, Part I, (2)(e)	REQ-RDPS-L-CONF-001 to -003 and REQ-RDPS-R-CONF-001 to -003
Annex I, Part I, (2)(f)	REQ-RDPS-L-INTEG-001 to -003 and REQ-RDPS-R-INTEG-001 to -003
Annex I, Part I, (2)(g)	Covered by the requirements in the core part of the standard
Annex I, Part I, (2)(h)	REQ-RDPS-L-AVAIL-001 to -003 and REQ-RDPS-R-AVAIL-001 to -003
Annex I, Part I, (2)(i)	Covered by the requirements in the core part of the standard
Annex I, Part I, (2)(j)	REQ-RDPS-L-AUTH-001 to -003, REQ-RDPS-R-AUTH-001 to -003
Annex I, Part I, (2)(k)	REQ-RDPS-L-AVAIL-002 to -003 and REQ-RDPS-R-AVAIL-002 to -003
Annex I, Part I, (2)(l)	Covered by the requirements in the core part of the standard
Annex I, Part I, (2)(m)	Covered by the requirements in the core part of the standard

Table R.6-2: CRA Annex I Part I gap analysis

Requirements of Regulation	Rationale / gap analysis
Annex I, Part I, (1)	Annex R identifies RDPS-boundary assets, associated security properties, aligned threats, and corresponding technical requirements. It does not itself define the manufacturer's risk assessment, but provides a technical framework to address RDPS-boundary risks once identified.
Annex I, Part I, (2)(a)	This is a broader product security, lifecycle, and vulnerability management obligation, not specifically an RDPS-boundary control.
Annex I, Part I, (2)(b)	This concerns broader product configuration requirements. Annex R is focused on RDPS-boundary interactions and does not itself define general secure-by-default product configuration requirements.
Annex I, Part I, (2)(c)	This concerns broader product lifecycle and update capabilities and is not directly addressed by the RDPS-boundary requirement set of Annex R.
Annex I, Part I, (2)(d)	The primary Annex R contribution is protection against acceptance of interactions whose source or origin is not genuine.
Annex I, Part I, (2)(e)	The confidentiality requirements protect exchanged RDPS interaction content where disclosure creates unacceptable risk.
Annex I, Part I, (2)(f)	The integrity requirements protect against modification, substitution, corruption, or injection of interactions.
Annex I, Part I, (2)(g)	This concerns broader product-level data processing and minimisation requirements. Annex R does not specifically address minimisation of RDPS-boundary exchanged or processed data.
Annex I, Part I, (2)(h)	These requirements address detection of unavailability, delay, or intolerable degradation, use of timeout or timeliness controls, defined degraded behaviour or secure state, support for recovery, and, at the stronger level, continuity of operation through failover, redundancy, or equivalent resilience mechanisms where necessary.
Annex I, Part I, (2)(i)	This concerns broader product or network impact beyond the RDPS boundary and is therefore addressed by the core part of the standard rather than by Annex R.
Annex I, Part I, (2)(j)	The core part of the standard is expected to address general attack-surface limitation. Annex R contributes only indirectly at the RDPS boundary by verifying source authenticity.
Annex I, Part I, (2)(k)	This is broader than the RDPS-boundary scope of Annex R. Annex R contributes indirectly through degraded behaviour, secure state, recovery support, and resilience measures, but does not provide a standalone exploitation-mitigation requirement family.
Annex I, Part I, (2)(l)	This concerns broader product-level logging, recording, monitoring, and user-facing control requirements.
Annex I, Part I, (2)(m)	This concerns broader product-level data and settings lifecycle management and is outside the RDPS-boundary interaction focus of Annex R.

Annex S (informative): Change history

Version	Date	Status
V1.0.0	20 July 2026	Final draft

History

Version	Date	Status
V1.0.0	August 2026	SRdAP process EV 20261105: 2026-08-13 to 2026-11-05